Техническое задание на маркетплейс услуг

JOBA

Версия 1.1 • 12 октября 2026 года

Название JOBA выбрано пользователем. Домен и юридическое лицо не выбраны.

Документ для владельца продукта, разработчиков, дизайнера, QA, DevOps и специалистов по праву и информационной безопасности.

Цель проекта: объединить заказчиков, которым нужна услуга, и исполнителей, которые ищут заказы по своим услугам. Продукт включает мобильные приложения iOS и Android, серверную часть, административную панель и адаптивный публичный сайт.

ТЗ описывает целевой продукт и минимально законченный первый релиз. Оно является основанием для оценки и реализации, но не подтверждает наличие готового приложения, подключенных платежей, рекламных договоров или юридических разрешений.

Зафиксировано пользователем: четыре страны, локализация, вход номером и паролем без SMS, сохраненная сессия с локальным PIN/биометрией, отсутствие пользовательской почты, обязательный документ исполнителя, двусторонний поиск, профили, взаимные оценки, модерация со словарями и временной автоблокировкой, подписка с управляемой ценой и рекламный способ доступа, постоянная опция подписки и независимое безкодовое включение баннерной и rewarded-рекламы. Постоянный бесплатный доступ не предусмотрен; администратор может назначить бесплатный промо-период подписки до выбранной даты с последующим платным тарифом.

Предложено в ТЗ: конкретный стек, интервалы, лимиты, модель ролей, SLA, сроки хранения и этапы. Эти параметры требуют утверждения владельцем продукта до разработки соответствующего блока.

Блокирующее решение: модель «подписка или реклама для всех основных функций» не признана автоматически совместимой с правилами rewarded-рекламы. Для России дополнительно ограничены платежные и рекламные каналы. Не запускать коммерческий доступ в стране до прохождения проверок разделов 20–22 и 41.

01 Как использовать это техническое задание

Документ задает поведение продукта, границы доступа, контракты между клиентами и сервером, критерии готовности и порядок запуска. Одна и та же учетная запись может выступать заказчиком и исполнителем. «Поиск работы» в этом ТЗ означает поиск разовых или проектных заказов на услуги, а не вакансии и трудоустройство.

Изменения v1.1 относительно выпущенной v1.0: выбрано название JOBA; добавлены портфолио FR-040, подробная карточка администратора/черный список FR-041–042 и встроенная поддержка FR-043; пользовательская почта полностью исключена, проверка документа исполнителя обязательна по FR-009; добавлены Топ-100 и продвижение FR-044–045 с единым управлением ценами. Репозиторий не переименовывается. Существующий чат заказа/отклика не меняется. Прежняя редакция не считается содержащей эти новые требования к портфолио.

Ключевые обозначения:

- MUST / «обязательно» — требование для приемки указанного релиза.
- SHOULD / «рекомендуется» — предлагаемое решение, изменение оформляется архитектурной записью.
- P0 — блокирует запуск; P1 — входит в первый рабочий релиз; P2 — отдельная последующая очередь.
- FR — функциональное требование; NFR — нефункциональное требование; AC — приемочная проверка; D — решение владельца.
- Право доступа, или entitlement, — серверное разрешение на набор действий до определенного срока либо исчерпания лимита.
- Страна аккаунта, регион хранения, страна услуги и витрина магазина приложений — разные поля; их нельзя без проверки сводить к одному значению.

При конфликте действует следующая последовательность: безопасность и обязательные требования применимого права; утвержденная политика магазина или провайдера; последние утвержденные требования владельца; это ТЗ; предложения команды. Конфликт оформляется как блокер, а не решается скрытым изменением бизнес-модели.

Навигация по разделам:

- 02–06: продукт, права, страны и архитектура
- 07–11: аккаунт, доверие, данные, профиль и поиск
- 12–18: заказ, отклик, чат, завершение, репутация и безопасность
- 19–23: доступ, подписка, реклама, ограничения и администрирование
- 24–31: защита, данные, API и события
- 32–34: реестр экранов и интерфейсные состояния
- 35–38: качество, проверки, приемка и эксплуатация
- 39–42: реализация, передача, решения и источники

Изменение требования получает номер версии, автора, причину, затронутые FR/AC, миграционный план и решение о совместимости. «Согласовано» фиксируется отдельно от «предложено». Цифры из этой версии нельзя автоматически считать утвержденным бюджетом или обещанным сроком команды.

02 Продукт и границы первого релиза

FR-001 P1. Заказчик ищет исполнителей по категории, месту, расстоянию, цене и репутации; создает заказ; получает отклики; выбирает исполнителя; общается; фиксирует результат и оставляет оценку.

FR-002 P1. Исполнитель создает профиль услуг, задает категории, географию, формат и ориентировочные цены; находит подходящие открытые заказы; откликается; выполняет выбранный заказ; оценивает заказчика.

Первый релиз должен быть законченной рабочей цепочкой: регистрация → законный доступ → поиск или публикация → отклик → выбор → чат → выполнение → завершение либо спор → взаимные оценки → поддержка. Заглушки разрешены только в разработке и демонстрационном окружении с явной маркировкой.

В P1 входят Flutter-приложения для iOS и Android, backend, админ-панель, публичный адаптивный сайт с описанием продукта, правовыми документами, поддержкой и ссылками на приложения. Полный личный кабинет заказчика и исполнителя в вебе — P2, если владелец отдельно не включит его в бюджет P1. Backend API проектируется пригодным для веб-клиента без смены доменной модели.

Все четыре страны входят в целевую архитектуру; публичный запуск каждой активируется отдельно после проверок локализации, договоров, провайдеров, хранения данных и платежей. Выключенная страна получает понятную страницу недоступности, а не нефункционирующую оплату.

За пределами P1: вакансии, кадровый учет, зарплаты, гарантия найма, комиссия со стоимости услуги, кошелек, эскроу, выплаты исполнителям, кредитование, страхование результата, видеосвязь, аукционы, маркетплейс товаров и автоматическое разрешение денежных споров. Стоимость самой услуги стороны согласуют самостоятельно; приложение хранит договоренность, но не обещает защищенный расчет.

P2: полноценный веб-кабинет, команды исполнителей, календарь свободных слотов, повторные заказы, избранные поиски, дополнительные языки, расширенная аналитика. Платежи за реальные услуги потребуют самостоятельного юридического и технического проекта.

03 Роли и матрица разрешений

FR-003 P1. Доменная роль не равна оплаченной подписке. Доступ проверяется сервером по аккаунту, роли, стране, состоянию объекта и действующему праву. Изменение интерфейса или подмена role в запросе не дает разрешений.

Действие	Гость	Заказчик	Исполнитель	Сотрудник
Правовые документы и поддержка	Да	Да	Да	По роли
Регистрация и выбор страны	Да	Да	Да	Нет
Полные результаты поиска	Нет	При праве	При праве	Только служебно
Создать свой заказ	Нет	При праве	В роли заказчика	Нет
Откликнуться на чужой заказ	Нет	После включения роли	При праве	Нет

Действие	Гость	Заказчик	Исполнитель	Сотрудник
Изменить чужой профиль	Нет	Нет	Нет	Только модерационное действие
Чат своего активного заказа	Нет	По участию	По участию	По обращению и полномочию
Экспорт и удаление аккаунта	Нет	Да	Да	Управление запросом
Цена и рекламные кампании	Нет	Нет	Нет	Billing или Campaign manager
Сырые документы личности	Нет	Нет обязательного сбора для customer	Собственная обязательная отправка	Отдельное ограниченное право

Служебные роли: support_agent, moderator, senior_moderator, verification_reviewer, billing_manager, campaign_manager, content_manager, security_auditor, country_admin, superadmin. Support видит минимальные сведения по обращению; moderator видит материалы дела; billing не видит документы личности; content не видит переписку.

Доступ сотрудников ограничивается странами и служебной целью. Для просмотра частного чата или защищенных данных обязательны номер обращения, причина и аудит. Выгрузка базы пользователей, массовая блокировка, смена payout-реквизитов провайдеров и глобальные тарифы требуют отдельного привилегированного сценария и второго подтверждающего сотрудника там, где предусмотрено.

superadmin не является повседневной ролью. Его доступ временный, с MFA, уведомлением security и записью действий. Сервисные учетные записи имеют только разрешения нужного модуля. Права проверяются на каждом HTTP-запросе, WebSocket-подписке и обращении к файлу.

04 Страны языки валюты и правовые версии

FR-004 P1. Локаль интерфейса выбирается независимо от страны услуги. Страна определяет каталог, правила допуска, правовые версии, платежные SKU и регион данных. Изменение страны не выполняет скрытый перенос персональных данных.

Страна	Код	Языки первого релиза	Валюта отображения
Сербия	RS	Сербский sr-Cyrl; sr-Latn предложен как вариант	RSD
Казахстан	KZ	Русский ru и казахский kk	KZT
Россия	RU	Русский ru	RUB
Беларусь	BY	Русский ru и белорусский be	BYN

Сербский алфавит по умолчанию и необходимость латиницы подтверждаются владельцем. Строки хранятся по ключам, ICU plural/select; текст не собирается из фрагментов. Проверить

кириллицу, казахские ә ғ қ ң ө ұ ү h і и белорусскую ў; исходные имена не транслитерировать автоматически.

Деньги: целое число минимальных единиц плюс ISO-код валюты; масштаб валюты берется из справочника. Не использовать float. Цена подписки показывается из магазина или активного провайдера, а не вычисляется по курсу. Время API — UTC RFC 3339, интерфейс — часовой пояс заказа/устройства с явно указанной зоной при договоренности о встрече.

Правовые документы имеют тип, страну, язык, номер версии, дату публикации и вступления, хеш и неизменяемый опубликованный файл. Согласие записывает пользователя, версию, цель, время и канал. Политика конфиденциальности показывается отдельно от маркетингового согласия; отказ от рекламы с персонализацией не блокирует доступ к управлению аккаунтом.

Адреса: страна → административный регион → населенный пункт → текст адреса → опциональная точка. Справочники версионируются; старые заказы сохраняют снимок адреса. Карта и геокодер подключаются адаптером, с проверкой лицензии, покрытия и разрешенной передачи координат в каждой стране.

Локализация проходит человеческую вычитку носителем. До публикации нельзя оставлять ключи вместо строк, машинные юридические переводы без проверки, неправильные формы множественного числа или несуществующие доступные провайдеры.

05 Целевая архитектура и стек

Предлагается модульный монолит на NestJS и TypeScript, PostgreSQL с PostGIS, Redis для краткоживущего кэша и лимитов, очередь задач, приватное S3-совместимое хранилище. Это снижает сложность первого релиза; границы модулей и outbox позволяют позднее выделять сервисы без немедленной микросервисной инфраструктуры.

Клиенты: Flutter для iOS/Android; Next.js и TypeScript для публичного сайта и админ-панели. Версии выбираются из поддерживаемых стабильных веток на старте реализации и фиксируются lock-файлами и ADR. ТЗ не разрешает автоматически применять устаревший major или случайную последнюю версию.

Модули: Identity, Accounts, Consent, CountryConfig, Catalog, Profiles, GeoSearch, Orders, Offers, Chat, Reviews, Moderation, Verification, Entitlements, Billing, Advertising, Notifications, Support, PrivacyRequests, AdminAudit. Контроллеры не вызывают базу другого модуля напрямую: изменения проходят доменные сервисы и типизированные контракты.

PostgreSQL — источник истины. Redis не хранит единственную копию прав, заказов, сообщений или платежей. Состояния изменяются транзакционно; запись события в outbox происходит в той же транзакции. Доставка событий и задач — как минимум один раз; потребитель идемпотентен.

Мобильный клиент использует presentation/domain/data слои, единое состояние авторизации, маршрутизацию с deep links, защищенное хранилище refresh token, локальный кэш с лимитом и очисткой при выходе. Финансовые права никогда не определяются только локальными настройками или часами устройства.

Публичный сайт не публикует реальные номера телефонов, адреса, документы или точную геолокацию. Индексация профилей поисковиками — отдельное согласованное решение, по умолчанию выключена. Админ-панель находится на отдельном origin и не использует пользовательские refresh tokens.

Интеграции скрыты за адаптерами: необязательный будущий OAuth, магазин подписок, web PSP, ad network, карты, push, проверка личности, антивирус. Каждый имеет sandbox/fake для локальной разработки, таймаут, retry policy, circuit breaker и country capability matrix. Реальный платный аккаунт не нужен для базового запуска репозитория.

06 Региональная изоляция и доверенные границы

FR-005 P0. До запуска утверждаются оператор данных, места первичного сбора и хранения, резервного копирования, перечень получателей и основание трансграничной передачи по каждой стране. Одна глобальная база по умолчанию запрещена как нерассмотренное решение.

Предлагается региональный data plane: отдельные базы, объектные хранилища, очереди, ключи шифрования, журналы и резервные копии по утвержденным регионам. Общий control plane содержит только несекретные версии конфигурации, публичные категории и агрегированную статистику без возможности восстановления личности.

Bootstrap выполняется до отправки телефона или пароля marketplace-серверу: клиент получает только публичную карту стран и endpoints, пользователь выбирает страну, затем register/login выполняется в соответствующем регионе. На новом устройстве пользователь явно выбирает исходную страну; автоматический перебор phone_e164 по всем базам запрещен. Сохраненный локальный region hint ускоряет повторный вход, но не заменяет серверную проверку.

Предложение P1: уникальность phone_e164 действует внутри региона, учетные записи разных регионов независимы; тот же номер в новой стране не переносит отзывы, подписку и данные. Глобальная дедупликация и предотвращение обхода межрегиональных санкций остаются блокирующим ADR-REGION-01 с правовой оценкой до запуска нескольких регионов. Нельзя обещать одновременно глобальную уникальность личности и отсутствие трансграничного реестра без отдельного решения. Если позднее добавляется OAuth, провайдер и его собственная обработка также входят в карту передач.

Регион пользователя фиксируется при создании аккаунта на основании выбранной страны и утвержденной политики; IP не является достаточным основанием. Переезд, работа через границу и смена страны требуют явного процесса с объяснением переноса, допустимости и судьбы активных заказов. До реализации такого процесса пользователь обслуживается в исходном регионе.

Каждый запрос несет проверенный region context; регион нельзя переключить клиентским заголовком. Access token содержит идентификатор региона и audience; сервер проверяет их. Идентификаторы сами по себе не обходят региональную изоляцию. Поиск по заказам и профилям ограничен разрешенным набором стран.

Внешние сервисы получают минимум данных. Push содержит непрозрачный event ID и нейтральный текст; загрузка деталей выполняется после авторизации. Аналитика, crash reports, логи CDN и резервные копии включаются в карту передачи данных, а не считаются техническим исключением.

Проверки: учетная запись RU не читает KZ объект через подмену ID; региональный backup не попадает в общий bucket; разработчик не копирует production в тест; межрегиональный export блокируется без разрешенного процесса; отключение одной страны не останавливает остальные.

Строгая изоляция может влиять на стоимость и возможность использования международного провайдера личности, восстановления, карт и рекламы. Не выбирать провайдера исключительно по удобству SDK. Подробные правовые источники и открытые решения приведены в разделах 41–42.

07 Регистрация по телефону и паролю

FR-006 P1. Зафиксировано последним уточнением пользователя. Регистрация: номер телефона и самостоятельно установленный пароль. Вход на новом устройстве: тот же номер и пароль. SMS-коды, телефонные одноразовые коды и SMS-интеграции полностью исключены, в том числе из восстановления. Телефон является неподтвержденным идентификатором входа, а не доказательством владения номером или личности.

До передачи телефона серверу пользователь выбирает страну аккаунта/регион и язык; запрос идет только в разрешенный региональный endpoint. На новом устройстве исходный регион выбирается явно, без автоматического поиска номера по всем базам. Номер нормализуется в E.164 с международным кодом: Сербия +381, Казахстан +7, Россия +7, Беларусь +375. Для +7 нельзя определять страну только по коду: проверять диапазон библиотекой телефонных планов, отдельно сохраняя выбранный data region. Форматная валидность не означает, что номер существует или принадлежит пользователю.

phone_status всегда unverified при такой регистрации. UNIQUE(region, phone_e164) предотвращает два аккаунта с одинаковым логином внутри региона. Если номер уже занят, нельзя объединять аккаунты, переносить подписку или заменять владельца по заявлению о номере. Показать нейтральное объяснение и путь в поддержку. Риск регистрации чужого номера и спор об идентификаторе признан отдельным риском; система не обещает устранить его без проверенного канала владения.

После регистрации: принять обязательные документы и возрастной допуск, настроить профиль/роли, получить право доступа. Пользовательский email отсутствует: не запрашивается, не хранится и не применяется для входа, уведомлений или восстановления. Google/Apple не входят в обязательный P1-сценарий. Если OAuth добавят позднее, применить правила магазина и безопасный link с issuer + sub; email claim не запрашивать и не сохранять.

Пароль хранится только как Argon2id hash с уникальной солью и версией параметров. Предложение: 15–128 символов, разрешены пробелы и Unicode, без обязательной искусственной смеси классов. Параметры KDF выбираются по актуальным рекомендациям и benchmark сервера; ориентир проверки 200–500 мс. Проверять распространенные/скомпрометированные пароли допустимым способом без отправки исходного пароля третьим лицам. Не логировать пароль и не сохранять обратимо зашифрованную копию.

FR-007 P1. Backend применяет rate limit и backoff по аккаунту, IP и устройству, защищаясь от brute force, credential stuffing и блокировки жертвы чужими попытками. Ошибка входа не раскрывает, существует ли номер. Access token предложено на 10 минут; refresh на 30 дней с ротацией, хранением хеша и отзывом token family при replay. Сессия сохраняется в защищенном хранилище устройства.

Пользователь видит свои устройства, может отозвать одно или все. Смена пароля требует текущего пароля/полной повторной аутентификации и отзывает остальные сессии. Восстановление требует решения D17 без SMS и email. Предложение: заранее выданный

случайный recovery code (показать один раз, хранить только hash, одноразовое использование) либо подтверждение доверенным устройством с зарегистрированным ключом и повторной аутентификацией; при утрате обоих — ручное дело поддержки по утвержденной проверке доказательств. Номер телефона, один IP, старый PIN и произвольно загруженный документ сами по себе не дают reset/merge/перенос владения. Для исполнителя поддержка может сопоставить законно сохраненный результат прежней ID-проверки; для заказчика обязательный ID этим не вводится. До утверждения D17 автоматического reset нет; доступен безопасный recovery chat FR-043. Процедура восстановления — P0 до публичного запуска.

08 Биометрия проверка личности и сигналы риска

FR-008 P1. Сохраненная сессия обязательно защищена локальной разблокировкой при открытии приложения: пользователь настраивает PIN и/или доступную биометрию. Если настройка отклонена или безопасный механизм недоступен, требуется полный вход номером и паролем. Поддерживаются Face ID/Touch ID на поддерживаемом iPhone, системный BiometricPrompt и допустимый класс биометрии на Android. Не называть Android-биометрию Face ID. Разблокировка открывает сохраненную сессию; она не создает новую серверную сессию и не заменяет проверку личности.

Предложение: PIN 6–8 цифр, блокировка при повторном открытии приложения и после 60 секунд в фоне, 5 неверных PIN-попыток → полная повторная аутентификация номером и паролем. Интервал и лимит утверждаются. PIN не отправляется серверу, не хранится открыто/простым быстрым хешем; использовать защищенный platform keystore/keychain, аппаратно защищенный ключ где доступен, KDF и защиту счетчика попыток от простого сброса. На устройствах без надежной защиты обязателен полный вход вместо разблокировки сохраненной сессии.

При изменении набора биометрии ключ локальной разблокировки инвалидируется, требуется полный вход и повторная настройка. Отозванная/истекшая серверная сессия не оживает после PIN/биометрии. Logout удаляет локальные секреты и приватный кэш; новый телефон не получает PIN старого. Приложение получает только результат системной биометрической проверки, не шаблон или изображение лица.

FR-009 P1. Обязательная проверка исполнителя. До допуска к исполнительским функциям пользователь загружает допустимый для страны документ: ID-карту либо паспорт. Набор типов, необходимые стороны/страницы и правовое основание утверждаются по стране; не собирать все страницы паспорта по умолчанию. Одна загрузка не означает verified: назначенный verification reviewer проверяет материал и принимает документированное решение. Для роли заказчика такая проверка не обязательна. Face ID/PIN не заменяют этот процесс.

Gate executor_verified проверяется сервером на публикации профиля и портфолио, полном поиске заказов в роли исполнителя, отправке/подтверждении отклика и принятии приглашения; выбор исполнителя заказчиком транзакционно проверяет его актуальный passed-статус. Черновик профиля, отправка документа, его статус, покупка/restore, privacy и поддержка доступны до проверки. Expired/revoked запрещают новую работу, но сохраняют разрешенное безопасное завершение/отмену действующего assignment; при угрозе — через поддержку. Customer capabilities не наследуют обязательный ID по факту наличия обеих ролей. Gate проверяется во всех REST/WS командах, не только UI; revoke и выбор исполнителя сериализуются по одному user verification guard, чтобы гонка не создала новый assignment после отзыва.

Состояния: not_requested → consent_required → pending_upload → pending_review → passed / rejected / needs_resubmission; passed → expired / revoked. Решение содержит reviewer, reason, timestamp, validity и policy version. Повторная загрузка создает новую ревизию; approve относится только к просмотренной актуальной ревизии. Rejected/expired дают понятное объяснение, исправление и апелляцию. Предложенный SLA — 1 рабочий день в заявленные часы. Значок «документ проверен» показывает проверенный факт/дату; не гарантирует отсутствие мошенничества, качество услуги или физическое владение аккаунтом предъявителем документа.

Country launch gate: законная модель обязательного сбора, локальное хранение/передачи, доступные способы проверки, обучение сотрудников и срок хранения утверждены до включения executor onboarding. Если законного процесса нет, исполнительский запуск в стране заблокирован. Liveness/распознавание лица не обязательны по этому ТЗ; их добавление требует отдельной необходимости, правового основания и оценки. Сравнение документов и фактов проверки не объявляется биометрическим поиском.

Исходники документов хранятся в отдельном зашифрованном приватном хранилище региона, недоступном обычной роли администратора. Просмотр требует специального permission, MFA/re-auth, причины и sensitive-read audit; signed URL предложен на 60 секунд с запретом публичного кэша. Нет документов в поисковой выдаче, push, логах, аналитике и тестовых данных. Предложение retention: удалить исходник через 30 дней после окончательного решения; незавершенный upload — через 24 часа, незавершенное дело — через 14 дней от первой загрузки без сброса таймера повтором. Последнее истекает с уведомлением и правом подать заново, а не считается fraud rejection. Исключение — конкретный законный hold; сроки утверждаются по стране и проверяются cleanup job. Оставлять минимальный результат/reference/срок проверки. DOB, полный номер и прочие поля сохранять только при обоснованной необходимости; если достаточно возрастного допуска, хранить результат 18+, не дату рождения.

Уполномоченный security-admin может видеть телефон, точный IPv4/IPv6 события, время, устройство, ОС, приложение и session ID. Это не точная геолокация: IP-регион помечен как приблизительный, город профиля — как указанный пользователем. GPS доступен только при соответствующем разрешении и допустимом назначении; обязательны accuracy, captured_at и retention. Пользовательская почта не собирается и не отображается.

Риск-сигналы: скорость регистраций, повторные отклики, жалобы, повторное использование платежной операции, аномальные сессии. Автоматический риск-скор может ограничить действие и отправить дело на проверку; окончательные значимые санкции требуют объяснимого процесса и апелляции. Непрерывное скрытое слежение запрещено.

09 Приватность согласия экспорт и удаление

FR-010 P0. Privacy center и поддержка доступны без оплаченного или рекламного права. Включить согласия, управление уведомлениями, доступ к документам, экспорт данных, удаление аккаунта и подачу апелляции. Для удаления в Google Play нужна также доступная внешняя веб-страница запроса.

Доступ к геолокации запрашивается в момент выбора «Рядом со мной», с объяснением цели. Отказ оставляет ручной выбор города и района. Точная точка жилого адреса не публична. Для каталога показывается район либо расстояние с округлением; участникам выбранного заказа

точный адрес раскрывается только в необходимом объеме и по согласованному действию заказчика.

Маркетинговое согласие, персонализация рекламы, аналитические cookies и обязательные условия разделены. Отзыв согласия действует на будущую обработку, не отменяя правомерные обязательные записи. ATT и другие системные разрешения не подменяются общим чекбоксом.

Предлагаемые сроки до юридического утверждения:

Данные	Предложение	Условие
Сырые GPS точки поиска	Не сохранять; технический кэш до 24 часов	Без истории маршрутов
События безопасности с IP	90 дней	Продление по активному инциденту
Обычные operational logs	30 дней	Маскирование персональных данных
Чат и материалы заказа	12 месяцев после закрытия	Спор и обязательный legal hold отдельно
Непрошедшие загрузки	24 часа	Автоматическая очистка
Сырые документы исполнителя	Предложено 30 дней после финального решения	Утверждение по стране; конкретный legal hold отдельно
Платежные и аудиторские записи	По применимому обязательному сроку	Не бессрочно по умолчанию

Экспорт формируется асинхронно после повторной аутентификации, включает JSON/CSV и собственные вложения, исключает чужие секретные данные и внутренние антифрод-сигналы. Архив зашифрован в хранилище, ссылка одноразовая или краткоживущая; готовность сообщается в приложении и разрешенным push без самого архива в payload.

Удаление: request → reauth → scheduled → erasing → completed либо limited_retention. Отмена возможна до erasing. Данные профиля удаляются/обезличиваются, сессии отзываются, поиск очищается. Законное удержание ограничивается конкретными полями, основанием и датой пересмотра; пользователь получает объяснение. Удаление аккаунта не выдается за отмену подписки магазина: показать отдельную инструкцию и подтвержденный статус.

10 Профили заказчика и исполнителя

FR-011 P1. Общий аккаунт содержит display name, аватар, языки общения, страну, статус и минимальную контактную информацию. Публичный профиль заказчика показывает имя, аватар, дату регистрации, количество завершенных заказов и подтвержденные взаимные отзывы. Телефон, платежные данные и документы скрыты; пользовательского email нет.

Профиль исполнителя содержит заголовок, описание, категории и подкатегории, форматы работы, опыт как собственное утверждение, галерею, города/зоны обслуживания, радиус выезда, язык общения, доступность, единицу цены и ориентировочную стоимость. «Цена от» обязательно маркируется; бесплатная услуга не подставляется при отсутствии цены.

Цена услуги: fixed / hourly / per_unit / negotiable; amount_min и optional amount_max в валюте страны; unit из справочника. Публичная цена не является оплатой внутри платформы. Дополнительные лицензии и квалификации публикуются только с типом проверки и сроком, без открытого изображения личного документа.

Состояния профиля исполнителя: draft → pending_review → published → paused / restricted / rejected. Пользователь может остановить получение новых предложений без удаления аккаунта. Изменение рискованных полей переводит только соответствующую версию на проверку; прежняя безопасная версия может оставаться видимой по политике модерации.

Валидации: display name 2–60 символов; заголовок до 100; описание до 3 000; до 10 категорий и 20 фото предложено для P1. Аватар обязателен только если владелец подтвердит это решение; отсутствие фото не должно провоцировать сбор изображения лица под видом обязательной идентификации.

Загрузка проходит инициирование, прямую отправку в приватное хранилище и finalize. До антивирусной проверки файл не отображается другим пользователям. Удаляются EXIF и встроенные координаты; создаются безопасные производные версии. Удаление элемента галереи не нарушает сохраненные материалы уже открытого спора.

При блокировке профиля старые отзывы не переписываются. В каталоге учитываются status, entitlement policy, модерация и локальные ограничения. Политика видимости профиля после окончания подписки определена в разделе 19 и явно объясняется пользователю.

FR-040 P1. Портфолио исполнителя. Добавлено в v1.1. В профиле исполнителя размещаются проекты с фотографиями работ, названием, описанием, категорией услуги и необязательной связью с выполненным заказом. Владелец создает/редактирует/удаляет свои проекты, меняет порядок и обложку. Предлагаемые лимиты: до 20 проектов, до 10 фото в проекте, до 5 MB на исходник; название 5–120 символов, описание до 3 000. Эти лимиты отдельны от галереи профиля и утверждаются до реализации. Видео в P1 не входит.

Состояния проекта: draft → pending_review → published / rejected; владелец переводит в archived. Из rejected или archived можно создать исправленную draft-ревизию и повторно отправить на проверку. Изменение опубликованного текста/фото создает новую ревизию; прежняя безопасная остается видимой до решения, если модератор не скрыл проект. Publish требует действующего права, executor_verified и доступного профиля; собственные draft CRUD, архивирование и история доступны без подписки. Чтение чужого published-портфолио наследует доступ к профилю, страну, pair block и ограничения раздела 19. Черновики и причины отклонения видны только владельцу и уполномоченному модератору.

Обложка выбирается только из безопасных фото текущей ревизии; минимум одно проверенное фото требуется для публикации. Reorder проектов и фото использует полную последовательность собственных ID и expected_version, атомарно исключая дубликаты/чужие ID. Upload проходит существующий приватный pipeline: MIME/decode/byte/pixel limits, scan, EXIF/геоданные удаляются, создаются thumbnail/lightbox variants. Непроверенные оригиналы и публичные permanent URLs не выдаются. Одобрение относится к точной текущей revision; устаревшее решение не публикует новую или удаленную версию. Удаление проекта скрывает его сразу, затем очищает файлы по retention; доказательства открытого дела сохраняются с ограниченным доступом.

Перед публикацией автор подтверждает права на фотографии и необходимые разрешения. Запрещены чужие персональные данные, адреса, контакты и изображения клиентов без надлежащего основания; UI предлагает убрать/обезличить их. Название и описание входят в server-side dictionary surface registry FR-037, совпавшая ревизия помещается в карантин до показа. Изображения можно пожаловать через общий report workflow; текстовый фильтр не обещает

распознавать содержимое фото. Модератор может скрыть проект, отклонить ревизию или запросить исправления с причиной и апелляцией.

Связь с заказом необязательна. Сервер разрешает ее только для собственного assignment исполнителя в completed, фиксирует order/revision reference и проверяет допустимость при каждом пересчете статуса. Значок означает только «связано с завершенным заказом в JOBA», а не доказанные авторские права/качество; после аннулирования completed значок снимается. Внешняя работа маркируется как самостоятельно заявленная. Заказчик открывает проекты из профиля, листает фото в доступном lightbox, видит описание/категорию/основание значка и может пожаловаться; чужой точный адрес и заказ не раскрываются.

11 Каталог поиск и география

FR-012 P1. Категории имеют стабильный ID, дерево с ограниченной глубиной, страну доступности, переводы, иконку из разрешенного набора и набор дополнительных полей заказа. Удаление используемой категории заменяется архивированием; существующие заказы сохраняют снимок названия.

Поиск исполнителей: текст, категория, город/район, радиус, дистанционно/выезд/у исполнителя, цена и единица, оценка с количеством отзывов, языки, статус проверки. Поиск заказов: те же географические признаки, категория, бюджет, период, дата публикации и состояние open. Один исполнитель не видит собственные заказы как возможность отклика.

Пагинация cursor-based с устойчивой сортировкой по score, published_at и ID. Ответ возвращает примененные фильтры, приблизительный total при необходимости и next_cursor. Нельзя рекламировать точность расстояния выше точности входных координат.

P1: PostgreSQL full-text search и нормализованные поля с trigram-индексом; PostGIS geography(Point, 4326) и ST_DWithin для расстояния в метрах. Фильтр страны и статуса применяется до выдачи. Для больших полигонов обслуживания хранить упрощенную геометрию и проверенный SRID; дистанционные услуги не требуют GPS.

Предлагаемое ранжирование: релевантность категории/текста, соответствие месту, доступность, надежность завершения, качество репутации с учетом количества оценок, свежесть. Весовые коэффициенты версионируются и проверяются на злоупотребления. Платное продвижение согласно FR-045 отдельно маркируется и не маскируется под органическую релевантность.

Пустые состояния: нет исполнителей → расширить радиус/другую дату/создать заказ; нет заказов → изменить фильтр; запрещенный регион → объяснение; нет GPS → ручной адрес; геокодер недоступен → сохраненный справочник. Нельзя обещать уведомления о новых заказах, пока пользователь не согласился и подписка на поиск не реализована.

Контактные данные и полные тексты результатов не доступны неавторизованному scraping. Rate limit задается по account/IP/device с учетом NAT. Поиск не возвращает заблокированные пары, скрытые профили, закрытые заказы или точные домашние адреса.

FR-044 P1. Топ-100 и реакции. Добавлено в v1.1. Два отдельных типа выдачи: открытые заказы заказчиков и карточки услуг исполнителей. Карточка услуги — существующий профиль × категория с устойчивым catalog_card_id, его описанием/ценой и ссылкой на профиль, а не новая вакансия или самостоятельный магазин товаров. Топ имеет фильтры country/city/category/target_type и показывает до 100 реально допустимых объектов; при меньшем

количестве не заполняется вымышленными. Действуют entitlement, страна, видимость, блокировки и executor_verified владельца карточки услуги.

Одна учетная запись может поставить одному чужому доступному объекту один активный like либо dislike, изменить выбор или убрать его. UNIQUE(voter_id, target_type, target_id), server-side eligibility, rate limit и idempotency предотвращают простые повторы; голосование за свой объект запрещено. Предложение допуска: авторизованный неограниченный аккаунт с действующим правом; для executor-only действия дополнительно V. Неподтвержденный телефон не доказывает уникального человека; подозрительные пачки направляются на review, а не дают гарантированную защиту от накрутки. Dislike сам по себе не является жалобой, доказательством мошенничества или основанием автобана.

Популярность учитывает допустимые like/dislike за версионируемое окно; больше likes при равных остальных факторах повышает organic score. Параметры и формула требуют утверждения: предложение score = max(0, ln(1+L) − α×ln(1+D)) × age_factor, окно 30 дней, α=0,5 и age_factor=exp(−age_days/30); все эти параметры предложены, версионируются и требуют утверждения. У новых объектов без реакций score=0; они ниже положительно оцененных, но доступны в сортировке «Сначала новые». Tie-break: score desc, valid likes desc, published_at desc, ID asc. Snapshot rank version/freshness делает cursor стабильным; recompute предложен каждые 5 минут. Изменение алгоритма имеет preview, version и audit; нельзя незаметно смешивать разные окна на соседних страницах.

Недоступный/удаленный/закрытый объект исключается из Топа и приема новых голосов; его реакции перестают влиять на актуальные агрегаты, а минимальная история сохраняется по retention. Повторное открытие новой попытки заказа не переносит голоса. Модерация может исключить доказанные накрутки с причиной и пересчетом. Пятизвездочная оценка рядом с карточкой — репутация связанного заказчика/исполнителя из реальных допустимых completed-заказов по FR-020. Произвольной кнопки «поставить 5 звезд объявлению» нет; likes/dislikes не создают отзывы и не меняют звездный рейтинг.

FR-045 P1. Платное и административное продвижение. Пользователь выбирает собственный допустимый заказ либо карточку услуги, место показа, страну/город/категорию и разовый срок: неделя, месяц или год. Пример «неделя за 200 ₸» не утвержденная цена. Неделя предложена как 7 суток, месяц/год — календарные периоды с серверной UTC-границей и явным отображением IANA zone; точная модель фиксируется offer snapshot. Для заказа boost end не может быть позже известного expires_at: несовместимые сроки, включая год для краткосрочного заказа, не предлагаются; заказ автоматически не продлевается. Preview объясняет прекращение показа при раннем выборе исполнителя/закрытии заказа и применимую refund policy. Автопродления по умолчанию нет. Продвижение не добавляет likes/звезды и не переписывает organic rank. Платные и административно продвинутые карточки находятся в отдельно обозначенных местах «Продвигается»; алгоритм органического Топа остается независимым.

Placement имеет ограниченную емкость и расписание ротации; purchase preview показывает место/срок и отсутствие гарантии первого места, показов, кликов или заказов. Reservation capacity транзакционна; предложенный срок удержания 10 минут. Checkout разрешен только при действующем праве, допустимом target и V для карточки услуги. Receipt activation и scheduled start повторяют eligibility/санкции/V/country/capacity checks. Boost не заменяет базовый доступ: его expiry/скрытие профиля приостанавливает показ без молчаливого продления. Сетевой banner toggle не отменяет уже выданные boost grants; это отдельный тип размещения. Покупка

цифрового продвижения в приложении использует разрешенную магазином схему/IAP, действующий SKU, store price points и country gate. Клиентская цена и success callback не являются подтверждением оплаты.

Состояния: draft → reserved → payment_pending → scheduled → active → expired; дополнительные paused / canceled / revoked / payment_failed / resolution_required. Сервер проверяет receipt, app/product/account/environment, подпись webhook и replay; UNIQUE(provider, transaction_id, benefit_type) выдает один boost grant. При позднем подтверждении после потери места/допустимости target деньги не выдумываются возвращенными: resolution_required, уведомление и разрешение через provider refund либо отдельно согласованное новое место. Старт/конец и provenance сохраняются в append-only ledger. Перекрытия одного target/placement по умолчанию отклоняются либо явно планируются последовательно до покупки; скрытого продления нет.

Если target скрыт/закрыт, действует sanction или обязательная проверка исполнителя утратила силу, показ прекращается; paid grant не удаляется из истории. Версионируемая policy определяет паузу, срок, компенсацию и допустимость refund до покупки. Предложение P1: пауза не продлевает календарный срок автоматически; сбой платформы рассматривается для компенсации, добровольное скрытие/нарушение — по раскрытым условиям и применимым правилам. Provider refund/chargeback отзывает остаток продвижения идемпотентно, без стирания заказа/отзывов; право апелляции сохраняется.

Администратор с promotion permission может бесплатно выделить карточку по собственным зафиксированным критериям: target, placement, причина, срок и actor. Это admin_grant с нулевой оплатой и provenance, а не фальшивая покупка; он проходит те же target/role/V/entitlement/country/time проверки при выдаче и старте; он тоже занимает емкость и маркируется как продвижение. Продление/отзыв требуют причины и аудита, не создают органических голосов. Дашборд разделяет paid/admin grants, pending/active/paused, реальные платежи/refunds и доступную емкость. PlacementPolicy имеет draft/validate/preview/publish, version и effective_at; новая емкость не ниже уже подтвержденных пересекающихся резервов/grants. Emergency safety stop скрывает опасный показ отдельно, с сохранением ledger и разбором оплаченных обещаний.

Единый ценовой инвариант. Все бизнес-цены платформы редактируются в админке: подписки, продвижение, скидки и промо по стране, валюте, сроку и аудитории. Нет hardcoded цен в клиентах/серверных сценариях. Price catalog хранит draft/effective versions и provider SKU; publish требует preview, ограничения price points/eligibility и подтвержденную синхронизацию магазина. Уже принятые условия не переписываются задним числом. Бюджет самого заказа и договоренная стоимость услуги задаются участниками и не меняются администратором через этот каталог.

12 Создание и публикация заказа

FR-013 P1. Заказ содержит категорию, заголовок 5–120 символов, описание 20–5 000, страну/город, формат выполнения, желаемый период, бюджет/валюту/единицу либо «по договоренности», до 10 фото, дополнительные поля категории и настройку раскрытия адреса. Обязательность полей возвращает серверная схема категории.

Черновик доступен владельцу и сохраняется на сервере; локальные изменения синхронизируются с version. Публикация проверяет роль, entitlement, профиль, страну, разрешенность категории,

модерационные ограничения и лимит активных заказов. Предложение: не более 5 открытых заказов на аккаунт с регулируемым лимитом по стране.

Состояние pending_moderation применяется при подозрительном тексте, ссылках, запрещенных товарах/услугах или риск-категории. Пользователь видит, что заказ еще не в выдаче. Автопроверка не должна отправлять материалы неразрешенному внешнему сервису.

До выбора исполнителя можно редактировать описание и срок. Существенные изменения бюджета, категории, места или объема создают новую ревизию; откликнувшиеся получают уведомление и должны подтвердить актуальность предложения. После выбора изменение основных условий возможно только через предложение поправки и подтверждение обеими сторонами; исходный снимок сохраняется.

Заказ не публикуется, пока хотя бы одно вложение находится в unsafe/pending scan, если оно входит в опубликованную ревизию. При ошибке загрузки пользователь может удалить вложение и повторить публикацию. Дубликат publish с тем же idempotency key возвращает тот же результат, без второго заказа и списания рекламного кредита.

Заказ становится expired после установленного expires_at, если не выбран исполнитель. Предложение: 14 дней по умолчанию, настраиваемо 1–30. Истечение закрывает новые отклики; до expires_at владелец может продлить срок при действующем праве; после expired разрешено только клонировать заказ в новый draft. Истечение подписки само по себе не помечает заказ выполненным.

Запрещены публикация вакансий, обход блокировок, размещение чужих персональных данных без основания и категории, запрещенные в выбранной стране. Справочник запретов и причины отказа локализуются и утверждаются до запуска.

13 Состояния заказа и защита от гонок

FR-014 P1. Сервер принимает только перечисленные переходы. Каждый переход проверяет роль, version, текущее состояние и отсутствие запрещающего moderation hold. Ограничение страны на новый бизнес не запрещает безопасно завершить уже выбранный заказ. Иные переходы возвращают 409 STATE_CONFLICT с актуальной версией.

Из состояния	В состояние	Инициатор и условие
draft	open	Владелец; publish прошел проверки
draft	pending_moderation	Сервер; требуется проверка
pending_moderation	open / draft	Модератор; одобрение / исправления
open	assigned	Владелец выбрал действующий отклик
open	cancelled	Владелец отменил с причиной
open	expired	Job; достигнут expires_at
assigned	in_progress	Исполнитель начал; обе стороны согласовали условия
assigned	cancelled	Отмена по согласованному процессу
in_progress	completion_requested	Исполнитель отправил результат

Из состояния	В состояние	Инициатор и условие
completion_requested	completed	Заказчик подтвердил результат
completion_requested	closed_unconfirmed	Старший модератор; рассмотрено молчание заказчика, доказательств принятия нет
completion_requested	in_progress	Запрошены доработки с причиной
assigned / in_progress / completion_requested	cancelled	Обоюдная отмена или решение модератора
Любое незакрытое	suspended	Модератор; обоснованная блокировка
suspended	Предыдущее допустимое	Модератор; снят hold и повторены проверки

completed, closed_unconfirmed, cancelled и expired терминальны для этой попытки заказа. Повторная работа оформляется новым заказом с reference исходного. Нельзя «переоткрыть» completed и перенести старый отзыв на новую работу. Аннулирование ошибочного завершения — отдельное аудируемое административное решение с пересчетом допустимости отзывов, без удаления истории.

Выбор отклика: транзакция блокирует строку order; сравнивает version; проверяет offer active, acknowledged_order_revision = current_revision и неистекшее право исполнителя на принятие и executor_verified; создает assignment с уникальным order_id; помечает выбранный offer accepted, остальные closed_not_selected; сохраняет снимок условий; пишет outbox. При одновременном выборе двух откликов побеждает только одна транзакция.

Срок завершения не выводится из часов клиента. Отсутствие ответа заказчика не превращается автоматически в подтверждение качества. Предложение: напоминания через 24 и 72 часа, затем обращение в поддержку через 7 дней; сроки утверждаются. Деньги за услугу платформа не удерживает и не распределяет. После эскалации поддержка запрашивает подтверждения обеих сторон; предложенный предел рассмотрения 7 рабочих дней. Если подтверждения приемки нет, старший модератор закрывает попытку как closed_unconfirmed с причиной и апелляцией. Это не completed, не доказанное качество и не основание для звездочного отзыва; нельзя оставить заказ навсегда в ожидании ответа.

Спор хранится отдельным case со ссылкой на заказ, а не разрушает его историю статусов. В открытом споре запрещены автоматическое закрытие, уничтожение доказательств и публикация неподтвержденной итоговой оценки. Разрешения на чат безопасности сохраняются.

14 Отклики и согласование условий

FR-015A P1. Из карточки исполнителя заказчик выбирает «Предложить заказ»: выбирает свой open-заказ либо создает новый, затем отправляет приглашение. Invite имеет pending / accepted / declined / expired / revoked, срок 72 часа и уникальную активную пару order + contractor. Принятие приглашения открывает заполнение обычного отклика; assignment и свободный чат сами собой не создаются. До отклика исполнитель может отказать без контакта. Лимит предложено 10 приглашений в сутки, с pair block и действующими правами обеих сторон.

FR-015 P1. Отклик может создать только активный исполнитель на чужой open-заказ в допустимой стране и категории. Проверить отсутствие pair block, санкции, превышения лимита, истекшего права и конфликтующего assignment. Повторные отклики одного исполнителя на один заказ запрещены уникальным ограничением.

Отклик включает сообщение до 2 000 символов, цену либо пояснение расчета, валюту заказа, предлагаемые сроки, срок действия и опциональные уточнения. Цена с иной валютой требует явного отказа API; конвертация не выполняется незаметно.

Состояния offer: draft → active → accepted / rejected / withdrawn / expired / closed_not_selected. Изменение active-отклика создает ревизию и сбрасывает подтверждение существенных изменений. withdrawn нельзя сделать accepted старым запросом. accepted меняется только через жизненный цикл assignment и заказа.

Заказчик видит список откликов с сопоставимыми ценами/единицами, рейтингом и количеством оценок, проверенными фактами профиля и условиями. Порядок по умолчанию не скрывает новые отклики ради платного продвижения. До выбора доступны уточняющие сообщения в отдельном треде этого отклика.

Выбор подтверждает снимок: order revision, offer revision, исполнитель, цена или метод расчета, сроки, адресный уровень, договоренности. Если ревизия изменилась после открытия экрана, API возвращает 409 OFFER_CHANGED; пользователь повторно просматривает новые условия. Нажатие «Выбрать» не списывает стоимость самой услуги.

Изменение условий после выбора: amendment pending → accepted / rejected / expired. Обе стороны видят старые и новые значения. Новая версия вступает в силу только после подтверждения адресатом. Условия не меняются при простом сообщении в чате без подтверждения, если пользователь явно не использовал сценарий согласования.

Антиспам: предложенные лимиты 10 откликов в час и 30 в сутки с возможностью настройки; одинаковые массовые тексты и ссылки дают risk event, а не автоматически пожизненный бан. Лимиты включаются в понятное сообщение с временем следующей возможности. Ошибка или сетевой retry не расходует дополнительный лимит.

Уведомления о выборе доставляются через outbox; их задержка не откатывает успешно выбранного исполнителя. Клиенты при возврате в приложение запрашивают актуальный order, а не доверяют только push.

15 Чат файлы и уведомления

FR-016 P1. До выбора создается разговор заказчик–исполнитель в контексте конкретного отклика; после выбора выбранный разговор становится рабочим чатом заказа. Не выбранные треды закрываются для новых сообщений, но остаются доступными в истории по сроку хранения. Прямые произвольные сообщения незнакомцам в P1 не предусмотрены.

Сообщение: server ID, conversation ID, sender ID, client_message_id, монотонный conversation sequence, type, text/attachment reference, created_at, edited_at и moderation status. Уникальность sender + client_message_id исключает дубликаты при повторной отправке. Сервер присваивает окончательное время и последовательность.

Состояния интерфейса: queued, sending, sent, delivered, read, failed. delivered означает подтвержденную доставку в активный клиент, read — максимальный просмотренный sequence;

push-провайдер не является подтверждением чтения. Переход sent → failed после принятия сервером недопустим.

Соединение WebSocket авторизовано и привязано к сессии. После reconnect клиент передает last_sequence, сервер догружает пропуски через REST. Повторные события возможны; клиент дедуплицирует по event ID. При отзыве сессии или блокировке доступ к подписке прекращается.

P1: текст, изображения и PDF; предложено до 10 МБ на файл, до 5 файлов в сообщении. Запрет исполняемых файлов, проверка magic bytes, MIME allowlist, antivirus, лимит распаковки, запрет активного HTML/SVG. Подписанная ссылка действует не более 5 минут и выдается только текущему участнику с доступом.

Редактирование текста предложено в течение 15 минут с отметкой и сохранением версии для расследования. Удаление у собеседника не должно уничтожать доказательства открытого спора; вместо него показывается tombstone. Административная проверка не может тайно послать сообщение от имени участника.

FR-017 P1. Уведомления: новый отклик, выбор, изменение условий, сообщение, запрос завершения, спор, санкция, апелляция, подписка и восстановление платежа. Настройки разделяют сервисные, чат и маркетинг. Уважать quiet hours; важные изменения доступны в in-app inbox. Не включать паспорт, точный адрес, полный текст личного чата или оплату в lock-screen push по умолчанию.

16 Завершение отмены споры и возвраты

FR-018 P1. Исполнитель запрашивает завершение с кратким результатом и допустимыми вложениями. Заказчик подтверждает либо просит конкретную доработку. После completed открывается право на взаимный отзыв. Подмена статуса через редактирование профиля или клиента невозможна.

До выбора заказчик отменяет open-заказ самостоятельно. После выбора предлагается причина отмены, а другая сторона подтверждает или оспаривает. Cancel request имеет pending → accepted / rejected / withdrawn / expired, version и expires_at; предложенный срок ответа 72 часа. Accepted переводит заказ в cancelled транзакционно, rejected создает спор по запросу инициатора, expired не означает согласие и дает путь в поддержку; два противоположных ответа сериализуются по version. При угрозе, мошенничестве или опасном контенте доступна немедленная safety report и прекращение контакта; платное право для этого не требуется.

FR-019 P1. Спор создается по заказу с категорией, описанием, желаемым исходом и доказательствами. Состояния: submitted → triaged → waiting_for_user / waiting_for_counterparty → under_review → resolved → appeal_open → final. Любой перевод сопровождается actor, timestamp, reason code и комментарием.

Разделить два типа обращения: качество/поведение в реальной услуге и цифровая подписка. В первом случае платформа модерирует контент, доступ и репутацию, но без сервиса расчетов не обещает возврат денег за работу. Во втором refund зависит от магазина или web PSP; решение платформы синхронизируется с подтвержденным статусом провайдера.

Предложенные сроки: подтверждение получения обращения сразу; первичная реакция поддержки за 1 рабочий день; safety-очередь повышенного приоритета до 4 часов в заявленные часы работы. Круглосуточный ответ нельзя заявлять без реально обеспеченной смены.

Модератор фиксирует перечень просмотренных материалов, результаты проверки, действие и понятное основание. Решения: no_violation, warning, content_removal, temporary_restriction, permanent_suspension, review_invalidation. Материалы не редактируются задним числом. Для пожизненной блокировки и спорного отзыва предусмотрена независимая апелляция старшему модератору.

Отмена заказа может учитываться в агрегированной надежности отдельно от звездочного рейтинга. Нельзя давать полноценный отзыв за невыбранный отклик или использовать отмену как единственный доказанный признак мошенничества. Оспоренный показатель маркируется и пересчитывается после решения.

Возврат подписки: webhook/проверка провайдера → отдельная ledger-запись → отзыв будущего доступа → сохранение минимального права завершить существующий заказ и обратиться в поддержку. Уже завершенная услуга и чужие отзывы не исчезают вследствие возврата цифровой подписки.

17 Взаимные отзывы и рейтинг

FR-020 P1. Обе стороны могут оценить друг друга только при наличии реального assignment и допустимого завершенного заказа. Уникальное ограничение order_id + author_id + subject_id допускает один отзыв в каждом направлении. Самооценка и отзыв постороннего аккаунта запрещены.

Отзыв: 1–5 звезд, текст до 2 000 символов, выбираемые критерии и отметка подтвержденного заказа. Критерии исполнителя: качество, соблюдение договоренности, коммуникация; заказчика: ясность задания, коммуникация, соблюдение согласованных условий. Публичные обвинения и персональные данные проходят модерацию независимо от числа звезд.

Предложенная защита от ответной мести: double-blind публикация после обоих отзывов либо через 14 дней от completed. До публикации сторона может изменить свой отзыв в пределах окна; после публикации доступно одно исправление в течение 48 часов с историей и повторной проверкой. Значения сроков требуют утверждения.

Если спор открыт до публикации, окно замораживается до решения; пользователю показывается причина. Отказ одной стороны оценивать не закрывает право другой. Отмена и недоказанное выполнение не дают звездочный отзыв; жалоба остается доступной. Удаление аккаунта автора не превращает отзыв в отзыв несуществующего подтвержденного лица: применяется утвержденная политика обезличивания или удаления с пересчетом.

Публичный рейтинг рассчитывается только по published и неаннулированным отзывам. Хранить сумму, количество, распределение 1–5 и дату обновления; округлять только на выводе. Сортировка может использовать байесовское сглаживание, но показываемые звезды и количество должны соответствовать реальным данным.

Антинакрутка: проверка циклических заказов, подозрительных пар, скоростей, повторяющихся устройств и контента; не публиковать внутренние сигналы и не утверждать их как доказанную вину. Сервер запрещает массовые оценки без выполненных заказов; flagged-отзыв уходит на ручную проверку.

Модератор может скрыть текст или аннулировать отзыв только по reason code, с уведомлением автора и субъекта, ссылкой на правило и апелляцией. Нельзя менять 1 звезду на 5, покупать

удаление отрицательного отзыва или давать сотруднику право создать отзыв от имени пользователя.

18 Блокировки жалобы и модерация

FR-021 P1. Предусмотрены два независимых уровня блокировки. Личная pair block скрывает будущие встречи в поиске и запрещает новые отклики/чаты между двумя аккаунтами. Платформенная санкция ограничивает действия пользователя глобально или в конкретной стране/категории по решению модератора.

Личная блокировка не удаляет историю заказа, отзыв или платежную запись. Если есть активный assignment, перед блокировкой объясняется влияние: новые несвязанные контакты запрещены; при обычном конфликте остается минимальная рабочая коммуникация, при угрозе чат замораживается и продолжение идет через поддержку. Решение не должно заставлять пользователя общаться с угрожающим лицом.

FR-022 P1. Жалоба доступна на профиль, заказ, сообщение, отзыв и рекламу. Категории: мошенничество, угрозы/насилие, оскорбление, спам, запрещенная услуга, персональные данные, ложная информация, нарушение рекламы, другое. Обязательны target ID, reason, описание при «другое»; вложения допустимы после сканирования.

Сервер создает неизменяемый снимок целевого контента и ссылки на версии. Пользователь получает case ID, состояние и сроки ожидания. Массовые жалобы не вызывают автоматический бан только по количеству; оценивать координацию и доказательства. Ложные жалобы не раскрываются оппоненту вместе с приватными сведениями заявителя.

Workflow: new → assigned → investigating → actioned / dismissed → appealed → upheld / overturned. Повторная жалоба по тем же фактам может связываться с делом, но не исчезает без подтверждения. Модератор не рассматривает собственное действие на финальной апелляции.

Санкции имеют scope, start_at, end_at, reason_code, evidence IDs, actor и уведомление. Temporary suspension истекает job-ом и повторной проверкой состояния; удаление Redis-ключа не снимает санкцию. Permanent suspension оставляет доступ к апелляции, экспорту, удалению и платежной поддержке.

Запрещенные категории, локальные возрастные ограничения и формы жалоб задаются по стране. Для потенциально опасных случаев интерфейс поясняет, что платформа не является экстренной службой. Передача информации государственным органам не автоматизируется без отдельного законного процесса и аудита.

Любое удаление контента из публичной выдачи имеет tombstone/статус; приватные материалы дела доступны только уполномоченной роли до истечения утвержденного срока.

18A Словари запрещенных слов и временная автоблокировка

FR-037 P1. Зафиксировано пользователем. Администратор заполняет словари запрещенных слов и фраз по стране и языку. При совпадении в пользовательском тексте сервер помещает нарушающий контент в карантин, временно ограничивает автора, создает дело и уведомляет уполномоченного администратора. Окончательное решение принимает человек; совпадение

слова само по себе не является доказанным мошенничеством или основанием автоматического постоянного бана.

Surface registry обязательно охватывает чат, заголовки/описания/текстовые атрибуты заказов, отклики, профили/имена/описания услуг, названия/описания портфолио и отзывы. Новое пользовательское текстовое поле нельзя добавить без записи в registry и теста фильтра. Проверка выполняется server-side до публичной записи/рассылки; изменение текста проверяется снова. OCR изображений и анализ речи не обещаются этим текстовым фильтром и требуют отдельной реализации.

DictionaryVersion содержит country, language, version, rules, exceptions, surface/category scope, effective_at и draft/published/retired. Rule имеет exact_word или phrase, нормализованное значение, whole-word boundary, reason code и severity. Использовать Unicode normalization NFKC и case folding с сохранением исходного безопасного снимка. Границы слова и пробелы во фразе определяются единым документированным алгоритмом. Произвольные регулярные выражения запрещены; длина фразы, число правил и время проверки ограничены.

Кириллическо-латинские подмены и невидимые символы обрабатываются только явно включенными правилами с preview; нельзя неконтролируемо заменять все похожие буквы и блокировать обычные слова. Смена языка интерфейса не обходит словарь: применять разрешенные словари страны и scope, а автоопределение языка считать вспомогательным сигналом. Exceptions и allowlist версионируются, системные сообщения исключены.

Процесс: draft → validate → dry-run preview → approve → scheduled/published. Preview показывает новые совпадения на разрешенном обезличенном корпусе, оценку ложных срабатываний и изменение охвата. Публикация не блокирует пользователей задним числом за старый текст. Ретроспективная проверка по умолчанию создает только очередь для ручного анализа; массовая санкция требует отдельного аудируемого решения.

Одна ModerationEpisode на content ID + revision + policy/dictionary snapshot атомарно создает один case, один hold и admin event. Совпавшие правила сохраняются дочерним списком ModerationMatch с rule ID/version, scope и masked context. Уникальность episode исключает дополнительные дела, hold и продление срока при нескольких совпадениях или retry; новое решение по тому же revision выполняется в существующем деле. Контент в quarantine не попадает в поиск, чат адресата или push preview. Автор видит понятный статус и ссылку на апелляцию.

Предложение, требующее утверждения: auto hold до 60 минут, первичная проверка до 15 минут в обеспеченные часы работы; duration/SLA настраиваются. Ограничены новые коммерческие действия и публикация, сохранены чтение истории, privacy, управление подпиской, поддержка и безопасная отмена/завершение через поддержку. Оплаченный срок и активные заказы не удаляются; таймеры спорных действий могут приостанавливаться по case policy. При истечении непросмотренного hold ограничение снимается, контент остается в карантине, дело эскалируется и администратор уведомляется. Автопродление бана без решения человека запрещено.

Администратор видит минимальный контекст, правило, время, страну и историю события. Решения: снять hold и одобрить/редактировать через автора/удалить контент; продлить с причиной и конечным сроком; применить постоянную санкцию вручную с правом апелляции. Чтение чувствительного контекста и все решения аудируются. Текст обращения/апелляции проходит отдельную очередь без повторной автоблокировки за цитирование оспариваемого

слова. Начальный рабочий словарь не выдумывается; тесты используют безопасные искусственные маркеры.

19 Модель доступа и права после истечения

FR-023 P1. Все основные marketplace-функции требуют действующего права, полученного оплатой, допустимым рекламным способом либо временным промо-периодом подписки по FR-036. Скачивание бесплатного приложения не означает бесплатное пользование основными функциями. Политика не должна скрыто меняться на постоянный freemium без решения владельца; любой промо-grant имеет конечный срок и источник.

Предлагается один базовый оплаченный entitlement marketplace_access для обоих пользовательских ролей; рекламный grant отдельно ограничен ролью и capabilities из snapshot. Набор оплаченного права: search_full, publish_order, send_offer, initiate_order_chat. Будущие раздельные тарифы заказчика/исполнителя возможны через capability, без смены identity role. Пользователь с двумя ролями не оплачивает дважды базовый доступ, если иное явно не утверждено.

Действие	Нет права	Действующее право	Право истекло при активном заказе
Управление аккаунтом и документами	Разрешено	Разрешено	Разрешено
Полный поиск и новый отклик	Paywall	Разрешено	Paywall
Новый заказ и новый контакт	Paywall	Разрешено	Paywall
Выполнить уже выбранный заказ	Не применимо	Разрешено	Разрешено в этом заказе
Чат существующего assignment	По участию	Разрешено	Разрешено до закрытия/хранения
Жалоба апелляция экспорт удаление	Разрешено	Разрешено	Разрешено
Восстановить покупку и возврат	Разрешено	Разрешено	Разрешено

При окончании права open-заказы и опубликованный профиль можно сохранять в базе, но исключить из нового коммерческого подбора, если это выбранная политика. Предложение: новые отклики и выбор исполнителя приостановлены, существующие невыбранные треды доступны только для чтения. Пользователь заранее видит предупреждение. Assigned и последующие состояния сохраняют безопасный доступ до завершения.

Сервер вычисляет effective rights по действующим grant-записям, санкциям и grandfathering конкретного order ID. Запрещено хранить единственный boolean is_paid. Право проверяется в начале изменяющей транзакции, списание одноразового кредита и действие атомарны. Повтор idempotency key не расходует право второй раз.

При недоступности entitlement-сервиса новые оплачиваемые действия fail closed; поддержка и локальная история не блокируются. Подтвержденный ранее order-scoped grant сохраняется в региональной базе, чтобы отказ Redis не оборвал активную работу. Изменение подписки не удаляет аккаунт и не обнуляет репутацию.

19A Подписка и независимые настройки рекламы

FR-031 P1. Зафиксировано последним уточнением пользователя. Подписка остается постоянным базовым способом доступа. Администратор может независимо включать и выключать баннерную рекламу Google или других заранее подключенных сетей. Rewarded-реклама, которая дает временный доступ, управляется отдельной настройкой. Режим отключения подписки не предусмотрен.

Настройка	Значение	Влияние на право доступа
subscription_enabled	Обязательная продуктовая опция	Подтвержденная покупка дает оплаченный grant
banner_ads_enabled	true/false по стране, роли и placement	Показ баннера никогда не создает grant
rewarded_access_enabled	true/false по стране, роли и платформе	Только подтвержденная награда создает grant
reward_policy	duration либо action_credits, размер, scope, лимиты	Ровно объявленные условия конкретной сессии

FR-032 P1. MonetizationConfigVersion содержит country, role scope, platform, banner_ads_enabled, rewarded_access_enabled, enabled providers/SKU, placements, reward policy, cooldown, daily cap, effective_at, policy evidence, version и статус. Подписку нельзя удалить переключателем рекламы. Если платежный канал в стране недоступен, UI честно сообщает причину; это блокер коммерческого запуска по разделу 22, а не разрешение показать фиктивный checkout.

Процесс без изменения кода: draft → validate → preview → approved → scheduled/published → superseded. Preview показывает страны/роли, цену из провайдера, баннерные места, награду, старые оплаченные права, начатые ad sessions и no-fill. Публикация требует второе привилегированное подтверждение. Rollback создает новую версию с прежними параметрами, не стирает audit и не отменяет ledger.

Клиент получает GET /me/monetization-config с version, ETag, effective_at, expires_at и server_time; обновляет на login/resume, по config.changed и не реже TTL 60 секунд при активном показе рекламы. 304 продлевает только подтвержденную актуальную версию. По истечении TTL без связи новые banner/reward requests запрещены, баннер скрыт; оплаченные и уже выданные рекламные права не отзываются. Таймер TTL использует монотонное время устройства, а сервер все равно проверяет новые reward sessions.

Отключение баннеров прекращает запросы к сетям и удаляет баннерные места на следующем безопасном обновлении конфигурации; новый SDK-сеанс не запускается. Оно не отменяет подписку, не меняет rewarded_access_enabled и не дает бесплатное core-право. Отключение rewarded прекращает создание новых reward sessions, сохраняя баннерные настройки и оплату. Выбор рекламы не является согласием на tracking; privacy/ATT применяются отдельно.

Начатая reward session сохраняет snapshot награды и role scope. Проверенный поздний callback выдает обещанное право даже после выключения rewarded, ровно один раз. Предложенное окно поздней сверки 72 часа; последующие подтвержденные случаи идут в recovery. Рекламное право заказчика не открывает send_offer, если награда для роли исполнителя не разрешена. Базовая оплаченная подписка по предложению покрывает обе роли.

При no-fill показывается конечное объяснение, повтор после cooldown и доступная подписка; принудительный бесконечный цикл запрещен. Rewarded включается только при подтвержденной совместимости полного core-paywall с правилами провайдера. Новые произвольные SDK, договоры и SKU нельзя подключить одной настройкой: они могут требовать разработки и магазинного релиза.

Предлагаемое правило, требующее утверждения: у платных подписчиков сторонние баннеры скрыты независимо от общего banner_ads_enabled. Управление подпиской, restore, отмена автопродления и оплаченный срок сохраняются при любых изменениях рекламы. Админ видит отчет о доходе, но платформа не обещает фиксированную выручку за просмотр.

20 Подписки цены и платежный учет

FR-024 P0. Доступ к цифровым функциям приложения рассматривается отдельно от оплаты физической услуги. Для подписки в iOS/Android использовать разрешенную правилами магазина схему. Нельзя считать исключение для физических услуг разрешением продавать цифровой доступ через произвольную внешнюю кнопку.

Plan содержит stable code, capabilities, период, страны и статус. PriceVersion содержит currency, amount_minor, provider, store product/base plan IDs, valid_from, valid_to, tax/display metadata и cohort policy. Менеджер создает черновик, проверяет ограничения магазина, публикует согласованную версию; клиент показывает цену из актуальных данных провайдера.

Администратор может управлять предлагаемой ценой по стране, но не переписывать уже заключенные условия без правил магазина, уведомлений и необходимого согласия. Изменение цены для новых покупателей и существующих когорт разделено. Цена в панели вступает в силу только после подтвержденной синхронизации SKU; конфликт помечается, продажа неверного SKU блокируется.

Покупка: клиент получает offer → запускает системный checkout → отправляет transaction reference → backend проверяет server API/подписанную транзакцию → сверяет app/package, environment, product, currency при наличии, ownership/account binding → атомарно пишет transaction и grant. Клиентский success callback сам по себе не дает право.

Состояния subscription: pending, active, grace, billing_retry, paused, expired, canceled_at_period_end, revoked. canceled_at_period_end сохраняет оплаченный срок. Grace разрешается только по подтвержденным правилам провайдера и не трактуется как новый бесплатный тариф. Expiry вычисляется по серверному expires_at.

Webhooks: проверка подписи, допустимого ключа/сертификата, issuer, аудитории и среды; защита от replay; unique(provider,event_id); durable inbox; ACK только после устойчивой записи. События могут прийти повторно и вне порядка: применять provider revision/effective_at, при конфликте перепроверять API, а не «последнее полученное побеждает».

Ledger append-only: purchase, renewal, refund, revoke, adjustment и связанный grant/reversal. Unique(provider, transaction_id), суммы в minor units, связи с исходной операцией; сумма возвратов не превышает подтвержденной суммы. Ежедневная reconciliation плюс targeted retry выявляют пропуски, не создавая второе списание.

Восстановление покупки доступно без paywall и проверяет владельца. Перенос одной магазинной покупки на другой marketplace-аккаунт не автоматический. Web PSP, если выбран, не хранит

номера карт на сервере платформы; отдельные договоры, налоги и возвраты требуют утверждения.

21 Реклама и выдача рекламного доступа

FR-025 P0. Рекламный путь — альтернативный источник entitlement, однако совместимость именно полного pay-or-ad ограничения должна быть подтверждена до запуска. У AdMob rewarded есть условие, что отказ/пропуск не должен препятствовать нормальному использованию приложения. Поэтому подключение rewarded SDK не считается доказательством допустимости желаемой модели.

Варианты после решения владельца: разрешенный провайдер с подходящими условиями; собственные спонсорские кампании с юридической проверкой; изменение бизнес-модели по отдельному согласованию. Никакое рекламное SDK не включается как обязательный доступ в спорной стране до проверки политики.

Предложение параметров, не утвержденный тариф: один подтвержденный просмотр выдает marketplace_access на 24 часа, суммарно не более 72 часов вперед, cooldown 30 минут, максимум 3 награды в сутки. Альтернатива — ограниченные action credits. Перед разработкой выбрать одну модель; UI показывает точную награду, срок и требуемое действие до старта.

FR-026 P1. Сессия награды создается сервером: account ID, network, placement, campaign, reward policy version, nonce, expires_at, pseudonymous custom_data. Для сетевой рекламы право выдается только по проверенному server-side verification callback или эквивалентному подтверждению провайдера. Проверять подпись, key ID, параметры, transaction ID и принадлежность сессии.

Unique(network, transaction_id) и unique(reward_session_id, reward_kind) исключают повтор. Callback может прийти поздно: клиент показывает pending и опрашивает статус; повторный просмотр не нужен для уже подтвержденной награды. Неподтвержденный клиентский event complete не выдает права. Время считают серверы; подмена часов телефона не продлевает доступ.

No fill, timeout, skip, app background, crash: объяснимое состояние, отсутствие списания, возможность повторить после допустимого интервала либо выбрать доступный платный способ. Если легального/доступного способа нет, страна не допускается к коммерческому запуску; бессмысленный цикл рекламы недопустим.

Собственная реклама проходит модерацию, сроки, бюджет, страну, локаль, возрастные и категорийные запреты. Серверная фиксация показа собственного видео использует одноразовую сессию и контроль последовательности, но не объявляется доказательством внимательного просмотра человеком. Риск мошенничества учитывается лимитами и аудитом.

Запретить политически/юридически недопустимые категории, вредоносные ссылки и выдачу награды за клик/установку без разрешенной политики. Реклама маркируется; можно пожаловаться. Публичный профиль не продается рекламодателю как идентификатор; передача SDK-данных включена в privacy review.

22 Матрица доступности провайдеров

Проверено по официальным источникам на 12 октября 2026 года. Это стартовые ограничения, а не гарантия договора, приема магазина, рекламного fill rate или будущей доступности. Повторная проверка обязательна перед релизом и при изменении политики.

Страна	Цифровые платежи	Сетевая реклама	Решение перед запуском
Сербия	Проверить publisher entity, SKU, валюты и магазинные условия	Проверить договор, инвентарь и rewarded policy	Полная тестовая покупка и легальный ad flow
Казахстан	Аналогично; отдельно договор и локализация данных	Аналогично; проверить передачу SDK-данных	Подтвержденные локальное хранение и передачи
Россия	Google Play Billing приостановлен; Apple покупки ограничены остатком баланса с 1 апреля 2026	AdMob Network/bidding не обслуживают пользователей в России	Не обещать стандартные subscription/ad flows; отдельная допустимая схема
Беларусь	Для бесплатных к скачиванию приложений IAP/подписки Google не затронуты блоком платных загрузок	Ограничение аккаунтов издателей, базирующихся в Беларуси, отдельно от аудитории	Проверить страну издателя, договор и фактическую оплату

В России Apple указывает возможность покупок из имеющегося баланса, при недоступности пополнения. Это не надежная универсальная основа подписки для новых пользователей. Не показывать неработающую покупку как единственный способ продолжить активный заказ.

Google сообщает о возможности управления third-party waterfall через AdMob для России с января 2025 года; это не возобновление AdMob Network и не автоматическая доступность стороннего спроса. Каждый сторонний источник требует отдельного договора, SDK/privacy review и технической проверки.

Отключение страны разделяет stop_new_business и emergency_safety_freeze. Первое блокирует новые регистрации/поиск/публикации/выбор, сохраняя существующий разрешенный чат, завершение/отмену, жалобы, restore/manage, экспорт и удаление. Второе может заморозить опасную коммуникацию, но всегда оставляет поддержку и права на данные; legal hold не отменяет их молча.

CountryCapability хранит platform, country, provider, capability, state (disabled / pilot / enabled / degraded), reason, evidence URL, checked_at, expires_at и approved_by. Feature flags дублируются серверной проверкой; старое приложение не обходит выключенный provider.

Перед включением страны нужны: прием приложения, договоры и юридическое лицо, платежный sandbox и live smoke test с разрешенной минимальной операцией, восстановление/возврат, для

включаемой rewarded-рекламы подтверждение награды и безопасный no-fill, локализованные правила и поддержка. Отсутствие хотя бы одного обязательного канала оформляется как release blocker.

Источники: Apple App Review 3.1.1, 3.1.3(e), 4.8; Google Play Payments; Google Russia/Belarus FAQ; Apple Russia purchases notice; Google publisher restrictions и rewarded policies. Точные ссылки приведены в разделе 42.

23 Административная панель

FR-027 P1. Web-панель адаптивна для рабочего ноутбука; критические массовые действия на узком экране требуют читаемого подтверждения. Вход сотрудников отдельный, MFA обязательно, сессия с idle timeout; роль и страна ограничивают каждый запрос.

Разделы панели:

- Пользователи: подробная карточка FR-041, телефон, роли, проверки, заказы, жалобы, санкции и история; пользовательской почты нет
- Заказы и отклики: состояние, история ревизий, assignment, дела; без произвольной правки согласованной цены
- Модерация: очереди, приоритеты, evidence, словари запрещенных слов, временные автоограничения, блокировки, апелляции и конфликт интересов
- Проверка личности: только статус и минимальные данные; документы отдельным привилегированным действием
- Категории и переводы: черновик, проверка, публикация, архивирование и country scope
- Тарифы: versioned планы, SKU mapping, цены и когорты, предпросмотр страны/платформы, синхронизация
- Реклама: собственные кампании, креативы, правила, бюджет/лимиты, расписание, жалобы и fraud rate; отдельные версионированные banner_ads_enabled и rewarded_access_enabled при постоянной опции подписки
- Поддержка и privacy: обращения, экспорт, удаление, legal hold с датой пересмотра
- Безопасность: сессии, события входа, приблизительные IP-регионы и риск-сигналы; GPS только при разрешенном сборе
- Аналитика и аудит: агрегированные воронки, подписки, завершение заказов, ошибки и история действий

Операции имеют preview, impact count, reason и подтверждение. Для массового изменения сохраняются selection snapshot и job ID; прогресс и частичные ошибки доступны отдельно. Экспорт ограничен сроком ссылки, полями, страной и назначением; событие записывается в audit.

FR-028 P1. Audit append-only: actor, impersonation flag, country, action, target type/ID, before/after безопасных полей, reason, request ID, timestamp, approval reference. Секреты, полные документы и содержимое частного чата не дублируются в журнале. Исправление — новая запись, удаление записей рядовым администратором запрещено.

Дашборд показывает определения метрик: активный пользователь, опубликованный заказ, принятие отклика, завершение, спор, refund, confirmed ad reward, no-fill, задержка webhook, revenue по валютам без фиктивного сложения разных валют. Доступ к детализации ограничивается ролями и минимальным размером агрегированной группы.

FR-033 P1. Доход рекламы отражается отдельно как estimated и finalized, с периодом, валютой, источником, временем получения и задержкой отчета сети. SSV подтверждает право пользователя, но не гарантирует оплату издателю. Финансовая сверка учитывает корректировки invalid traffic и не складывает показы с деньгами. Доход не гарантируется: зависит от договора, заполнения и результатов сети.

Админ-панель не позволяет скрыто входить под пользователем. Если support impersonation понадобится в P2, потребуется отдельный auditable read-only режим с явной маркировкой и исключением платежных действий.

FR-041 P1. Подробная карточка пользователя. Администратор в пределах country scope и полевых permissions открывает страну аккаунта, город профиля с source=self_reported, полный телефон со статусом unverified, даты регистрации/входа, security events с полным IPv4/IPv6, устройствами и сессиями, роли/ID-статус, заказы, жалобы, обращения, блокировки и историю решений. Нет поля пользовательской почты. Разделы имеют фильтры даты/статуса и cursor pagination; переход в дело сохраняет permission. Поиск по user/order/case ID, разрешенному телефону, стране/городу; поиск по IP доступен только security permission с причиной. Запросы не раскрывают пользователей другого региона. IP — адрес сетевого события, не доказанная точка проживания; GPS не появляется без разрешенного сбора.

Чувствительные поля скрыты до проверки соответствующего права; просмотр/экспорт полных IP, контактов и документов аудируется. Нельзя дать полный доступ к паспорту всем администраторам через общую карточку. Экспорт требует отдельного permission и минимального scope, имеет срок скачивания. История не бессрочна: действует retention по назначению и законные hold. Поиск по документам ограничивается разрешенным case/reference; биометрический поиск или неконтролируемый глобальный реестр лиц не предусмотрены.

FR-042 P1. Черный список и удаление. Старший модератор вручную создает внутреннюю blacklist-запись со ссылкой на дело, категорией/причиной, доказательствами, scope, началом/концом либо обоснованным постоянным сроком, actor и правом апелляции. Состояния active → expired / released / overturned. Временный автоматический hold по словарю не объявляет человека доказанным мошенником и не превращается сам в постоянный blacklist. Пользователь получает понятную причину и путь в поддержку; публичной доски обвинений нет. Новые коммерческие действия запрещены, оплаченная история/обращения/privacy и безопасное разрешение действующих заказов сохраняются.

Удаление администратором — отдельный privacy workflow, не синоним бана: привилегия, повторная аутентификация, preview затронутых объектов, основание и второе подтверждение. Scheduled deletion отзывает сессии/скрывает профиль; hard deletion выполняется после утвержденного окна и проверки retention/legal hold. Сохранять допустимый минимальный audit вместо копии всех пользовательских данных; нельзя навечно удерживать полный паспорт «на всякий случай». Удаление не отменяет подписку магазина автоматически. Ошибочный бан снимается отдельным решением без восстановления уже правомерно удаленных данных. Система не обещает исключить все повторные регистрации или мошенничество.

FR-043 P1. Встроенная поддержка и восстановление доступа. Пользователь ведет приватный чат с сотрудником внутри приложения; почтовых tickets и пользовательского email нет. Доступ без подписки, при sanction/expiry и из privacy center. Авторизованному пользователю доступны собственные обращения и история. Переходы: new → assigned → waiting_user ↔ waiting_support → resolved; новый ответ владельца допускает reopened → assigned в разрешенном окне.

Status/assign команды проверяют version и роль. У сотрудника очередь, назначение, ответ от имени поддержки, internal notes с отдельным ACL и связанные case IDs. Сообщения используют seq, client_message_id, reconnect/dedupe, безопасные вложения и in-app/push; поддержка не пишет от имени пользователя.

До входа: выбрать регион → создать recovery thread → получить непрозрачный ticket ID и случайный secret capability, сохраненный защищенно на устройстве. Capability передается в Authorization, не URL/аналитику/логи, дает доступ только к этому ограниченному чату; server хранит hash. Предложены срок 72 часа с безопасным продлением активного обращения, rate limits по IP/устройству/региону и anti-bot challenge по риску. Pre-login чат P1 только текстовый, вложения не принимает; требуемое D17 доказательство передается лишь через отдельно утвержденный защищенный процесс, не обычную анонимную загрузку. Ответ не подтверждает наличие аккаунта с заявленным номером. Новый ticket не показывает прежние пользовательские чаты, заказы или документы. Если capability утрачен, новый чат не наследует старый автоматически.

Привязка pre-login чата к аккаунту и восстановление выполняются только после предусмотренной D17 проверки владения; введенный номер не дает reset. До утверждения policy оператор помогает и фиксирует дело, но не обходит запрет выдачей пароля/токена. Секреты, recovery codes и пароли не пересылаются сотруднику в чате; проверка кода идет отдельным защищенным контролем после утверждения реализации. Жалоба/апелляция/поддержка с цитатой запрещенного слова не запускает повторную автоблокировку; применяется отдельная ручная очередь и антиспам. История и вложения авторизованного чата удаляются по обоснованному retention, а не хранятся вечно.

23A Баннерные места рассылки и расписание стоимости

FR-034 P1. Зафиксировано пользователем. Баннеры размещаются внутри экранов приложения в ненавязчивых inline-местах. Placement имеет стабильный ID, экран, разрешенный формат, зарезервированный размер, частотный лимит и country/role policy. Предложение P1: конец блока каталога, разделитель между группами карточек и необязательный слот главной страницы. В чате, оплате, выборе исполнителя, вводе заказа, проверке личности и privacy/support баннерные места отсутствуют.

Баннер не перекрывает кнопки, поля, клавиатуру и системные элементы, не меняет внезапно положение основного действия и не блокирует переход между экранами. При no-fill зарезервированное место убирается безопасно до взаимодействия либо сохраняет стабильную компоновку без пустой ловушки. Запрещены фальшивые кнопки приложения, принудительный клик и выдача grant за обычный баннерный показ. Реклама маркирована и соответствует политике сети. Вознаграждение владельцу показывается по отчетам сети, без гарантии оплаты каждого показа.

FR-035 P1. Администратор управляет push-кампаниями: draft, preview, test, scheduled, sending, completed, canceled. Поля: название, тип service/marketing, страны, языки, роли, локализованные title/body, разрешенный deep link, send_at, time_zone, дедлайн доставки, лимит частоты и автор. Preview показывает аудиторию и пример экрана; тест идет только на заранее разрешенные тестовые аккаунты.

Marketing отправляется только пользователям с действующим согласием и разрешенным каналом. Сервисная категория не позволяет маскировать рекламу под обязательное сообщение. На момент отправки повторно проверяются consent, country, session/device, suppression и quiet hours в часовом поясе получателя; отправка переносится в разрешенное окно до дедлайна либо пропускается; proposed cap для marketing — 1 кампания в сутки и 3 в неделю. Отмена scheduled останавливает будущие отправки; уже принятые push-провайдером сообщения нельзя обещать отозвать.

Deep links выбираются из allowlist routes: order, offer, conversation, profile, notification, subscription, help. Произвольный JavaScript/внешний URL не выполняется. Приложение проходит auth, region, object access и entitlement checks; недоступный объект дает безопасное объяснение. Payload не содержит точного адреса, документов или чувствительного текста. Campaign ID и уникальный recipient/event key предотвращают повтор при retry; delivered не равен read.

FR-036 P1. Зафиксировано пользователем. Речь о цене подписки: администратор задает «0 до выбранной даты, далее платный тариф». Комиссия с выполненного заказа не входит в проект первого релиза. Schedule содержит plan, country, role, audience (новые/существующие/все), valid_from, promo_end_exclusive, IANA time zone, следующий amount/currency/period и проверенный provider SKU. UTC-граница вычисляется сервером; UI показывает дату, время, зону и будущую цену. Если выбрана только календарная дата, preview явно задает окончание в 00:00 следующего дня этой зоны.

Базовая реализация нулевого периода — серверный promo-entitlement с конечным сроком; магазинный SKU не переписывается в произвольный ноль. Допустимый store trial/offer возможен отдельным адаптером по правилам магазина. Grant связывается с promotion_id, config version и account; повторное получение не продлевает фиксированную границу. Перекрывающиеся активные промо одного scope запрещены. Черновик проходит validate/preview/schedule/publish/cancel с аудитом и проверкой доступности следующего платного продукта.

В момент promo_end_exclusive новые основные действия требуют оплаченного либо разрешенного рекламного права. Приложение показывает актуальную цену и законный checkout, но не списывает деньги автоматически: бесплатное пользование не означает согласия на оплату или автопродление. Уже оплаченные сроки не уменьшаются, возврат предыдущей оплаты не создается автоматически, активные заказы сохраняют safety scope. Отмена опубликованного промо останавливает выдачу новых grants, а ранее обещанный срок сохраняется; изменение действует только на новую версию условий.

FR-038 P1. Иконка приложения. Администратор загружает исходник настоящей launcher-иконки через панель, задает автоматическую/ручную квадратную обрезку, видит preview iOS/Android и сохраняет версию брендинга. Предложение: PNG от 1024×1024 px, лимит 5 MB и 4096×4096 px; числа утверждаются. Сервер проверяет MIME и декодирование, размеры/число пикселей, удаляет метаданные, сканирует файл; защищается от pixel bomb. SVG/активные форматы по умолчанию запрещены. Непроверенный исходник приватен; crop не искажает пропорции.

Workflow: draft → preview → approve → generate → build/test → отдельное разрешенное submission/release. Генератор готовит iOS AppIcon assets и Android mipmap/adaptive foreground/background, проверяет safe zone и варианты маски; для adaptive canvas 108×108 dp важное содержимое в центральных 66×66 dp. Версия неизменяема и связана с checksum, build ID и результатами проверок. Rollback выбирает прежний исходник для следующего релиза, не

меняет уже установленные приложения. Store-listing icon отдельна: Google Play требует 512×512 PNG; это не замена launcher icon.

Произвольная новая картинка на домашнем экране требует новой сборки и распространения обновления. Загрузка в админке сама по себе не публикует приложение в магазине. Необязательное P2: выбор только заранее встроенных alternate icon ID; iOS использует supportsAlternateIcons/setAlternateIconName и системный alert, Android — объявленные activity-alias с packaged resources и проверку разных launcher/OEM. У пользователя должны быть знание и согласие на изменение и путь возврата. Remote config не превращает внешний URL в новую launcher-иконку и не гарантирует мгновенную смену на всех устройствах. Иконки категорий и произвольное изменение UI не добавляются этим требованием.

FR-039 P1. Реферальные привилегии. Пользователь делится своей ссылкой/кодом и получает настраиваемую привилегию за приглашения. Пример «5 человек, подписка 500 → 200 ₸/месяц» описывает пожелание механики, а не утвержденный тариф, порог или бессрочную скидку. Базовая схема одноуровневая: вознаграждается прямой пригласивший; денежных выплат и многоуровневых комиссий нет.

Администратор создает ReferralCampaignVersion: country/role, qualifying_event, threshold, attribution_window, benefit_type (fixed_discount / percent_discount / free_period / feature_benefit), amount/currency либо capability, duration, caps, stacking, audience, budget, start/end и разрешенный provider offer. Предложение qualifying_event: первая подтвержденная оплата либо завершенный допустимый заказ; одна регистрация может быть выбрана только после явной оценки злоупотреблений. Campaign проходит draft/validate/preview/approve/schedule/publish/stop с аудитом. Для скидки обязательны поддержка магазина, eligibility и допустимый price point; сервер не переписывает будущие списания App Store/Google Play произвольной суммой.

Код непрозрачен, подписан/проверяем сервером, не содержит персональных контактов. Universal/App Links ведут в приложение; предусмотрены web fallback и ручной ввод кода. Атрибуция выполняется сервером в утвержденное окно по первому действительному приглашению и показывается пользователю до фиксации. UNIQUE(invited_user_id) внутри разрешенного data region дает одного пригласившего; self-invite запрещен. Межрегиональный перенос и дедупликация зависят от ADR-REGION-01. Неподтвержденный номер или смена устройства не доказывают уникального человека; скрытый fingerprinting не используется. Рискованные связи направляются на review без обвинения пользователя.

Referral: attributed → pending → qualified / rejected; награда: issued → redeemed / expired / revoked. Событие квалификации, threshold milestone и reward ledger идемпотентны: retry не начисляет второй бонус. Snapshot кампании фиксируется при атрибуции, обещанные сроки заработанных прав сохраняются при смене условий. Refund/chargeback до квалификации отменяет pending; после выдачи создает compensating event и проверку по опубликованной policy, а не незаметное удаление ledger/списание денег. Fraud reversal допускается с причиной, уведомлением и апелляцией. Redeem повторно проверяет актуальный provider offer и согласие на платную подписку; если предложение недоступно, награда не сгорает молча и доступна поддержка.

Экран пользователя показывает ссылку/код, правила, прогресс к порогу, pending/qualified количества, привилегию и дату окончания; не раскрывает чужие покупки и контакты. Admin dashboard показывает воронку, выданные/погашенные награды, расходы кампании, лимит бюджета и очередь аномалий. До фиксации обещания сервер атомарно резервирует максимальную стоимость награды по milestone с учетом уже имеющегося резерва. При нехватке

бюджета новая атрибуция не фиксируется; UI объясняет лимит. При issued резерв становится расходом; rejected либо заранее объявленный конец окна квалификации освобождает резерв. Остановка кампании сохраняет резервы принятых обещаний.

24 Защита приложения и инфраструктуры

NFR-SEC P0. Использовать OWASP ASVS как основу проверок web/API и MASVS для мобильных клиентов; конкретные версии и применимые контроли фиксируются в security checklist при реализации. Цель — подтвержденные меры и тесты, а не неподтвержденный знак сертификации.

TLS на внешних соединениях; шифрование дисков, объектов и резервных копий; отдельные ключи окружений/регионов; секреты в secret manager. В репозиторий не попадают токены, private keys, реальные receipts, ID-документы, переписка или персональные production-данные. .env.example содержит только безопасные имена и фиктивные значения.

API: schema validation, allowlist полей, parameterized SQL, object-level authorization, защита от mass assignment, BOLA/IDOR, SSRF и injection. URL для внешних вложений не принимаются вместо разрешенного upload ID. CORS только разрешенные origin; web auth cookies Secure, HttpOnly, SameSite и CSRF-защита там, где используются cookies.

Rate limits по маршрутам и аккаунтам с корректной обработкой reverse proxy; доверять forwarded IP только известному ingress. Register, login, password change, search, offer, upload и report имеют отдельные бюджеты. Ответ 429 включает Retry-After и не раскрывает существование чужого аккаунта.

Мобильное приложение: Keychain/Keystore для токенов, запрет секретов в logs/crash, очистка кэша при выходе, защита deep links, безопасная обработка web views, минимальные permissions. Root/jailbreak/attestation — риск-сигналы, не единственное основание лишить человека поддержки или доступа к данным.

Файлы: приватный bucket по умолчанию; случайный object key; связь владельца с upload record; лимиты размера и числа; MIME+magic validation; quarantine до scan; удаление EXIF; безопасная генерация thumbnails. Публичный URL только для утвержденной производной версии, если privacy policy это допускает. Backup вложений сохраняет тот же режим доступа.

Админ: обязательная MFA, отдельный auth audience, idle timeout предложено 15 минут, повторная аутентификация для привилегированных действий, least privilege, периодический review и немедленный offboarding. Сотрудник не видит чувствительные поля только из-за знания user ID.

Release gate: threat model; скан зависимостей и секретов; SAST; API authorization tests; внешний или независимый pentest до широкого запуска; ноль открытых critical/high без письменного risk acceptance. Incident runbook включает утечку данных, компрометацию admin, fraud платежей, потерю ключа и отключение провайдера.

25 Модель данных основного продукта

Все ID — непрозрачные UUID; даты timestamptz; суммы bigint minor units; status ограничен enum/check; mutable агрегаты имеют version. FK обязательны там, где граница региона/модуля позволяет. Удаление каскадом не применяется к audit, ledger и доказательствам автоматически.

Сущность	Основные поля	Ключи и индексы
users	id, region, country, status, phone_e164, phone_status=unverified, display_name, city_id, city_source, locale	PK id; UNIQUE region/phone_e164; country/status
password_credentials	user_id, argon2id_hash, parameter_version, changed_at, reset_state	PK user_id; no raw/reversible password
identities только будущий OAuth	user_id, issuer, subject, provider, linked_at	UNIQUE issuer/subject; не обязательны для P1
sessions	user_id, refresh_hash, family_id, device, expires_at, revoked_at	UNIQUE refresh_hash; user/expiry
consents	user_id, document_version_id, purpose, accepted_at, withdrawn_at	user/purpose/version; append history
customer_profiles	user_id, public_summary, reputation_id	PK user_id
portfolio_projects / portfolio_revisions	owner_id, category_id, title, description, state, revision, position, optional assignment_ref	Owner/state/position; immutable revisions; completed-link check
portfolio_images	revision_id, upload_id, position, cover_flag, variant_refs	UNIQUE revision/upload и position; одна cover; safe-scan FK
contractor_profiles	user_id, status, revision, bio, price_mode, service_point	PK user_id; GiST point; status/country
profile_categories	catalog_card_id, profile_id, category_id, country	UNIQUE profile/category; stable catalog_card_id
listing_votes / ranking_snapshots	voter, target_type/id, value, state, window, algorithm_version, score, rank, as_of	UNIQUE voter/target; eligible-target filter; country/type/rank
placement_policy_versions	scope, capacity, rotation, draft/status, effective_at, version	Overlapping promised capacity floor; atomic publish
boost_offers / reservations / grants	target, placement/scope, capacity_slot, price_version, starts/ends, state, source, ledger_ref	Capacity lock; provider transaction dedupe; target/placement overlap check
service_areas	profile_id, city_id, radius_m, polygon, remote	GiST geometry; profile/city
categories	id, parent_id, status, schema_version	parent/status; cycle validation
referral_campaign_versions / referrals / referral_rewards	campaign snapshot, inviter/invited, qualifying_event, milestone, benefit, expiry, ledger_ref, budget_reservation	UNIQUE invited_user; event/milestone dedupe; attribution budget lock
brand_icon_versions / brand_icon_builds	source_ref, crop_rect, dimensions, checksum, generated_set, approval, build_id, status	Immutable version; scan/approval checks; release audit
category_translations	category_id, locale, title, normalized_title	UNIQUE category/locale; text index
orders	owner_id, country, status, current_revision, expires_at, selected_offer_id	owner/status; country/category/status/time; GiST point
order_revisions	order_id, revision, category_schema_version, typed_attributes, title, description, price, schedule, private_address	UNIQUE order/revision

Сущность	Основные поля	Ключи и индексы
order_invites	order_id, contractor_id, state, expires_at	Partial UNIQUE order/contractor WHERE pending
offers	order_id, contractor_id, status, revision, acknowledged_order_revision	UNIQUE order/contractor; order/status
offer_revisions	offer_id, revision, price, terms, valid_until	UNIQUE offer/revision
assignments	order_id, offer_id, contractor_id, terms_snapshot, state	UNIQUE order_id; UNIQUE offer_id
cancel_requests	order_id, proposer_id, state, version, reason, expires_at	order/state; одно pending; terminal без повторного решения
amendments	assignment_id, proposer_id, old_version, proposed_terms, state	assignment/state

Точная геометрия заказа хранится отдельно от публичной аппроксимации. Поле private_address шифруется/защищается по утвержденной модели доступа; в поисковую проекцию оно не копируется. Индексы содержат только необходимое; наличие индекса не дает permission.

Для календаря и количества активных объектов не использовать count на всей таблице в каждой карточке. Производные counters обновляются транзакционно либо через идемпотентные события и периодическую сверку. Полнотекстовый индекс формируется с учетом локали; rank и text normalization покрываются тестовыми корпусами всех языков.

Ревизии и снимки договоренности неизменяемы. CHECK обеспечивают positive radius, price_min ≤ price_max, допустимую валюту и период start ≤ end. Уникальность выбранного исполнителя гарантируется базой, а не только предварительным SELECT.

26 Данные общения денег рекламы и аудита

Сущность	Основные поля	Ключи и ограничения
notifications	user_id, event_id, type, safe_payload, created_at, read_at	UNIQUE user/event_id; user/read_at/time
conversations	order_id, offer_id, type, status, last_sequence	UNIQUE offer_id; participants checked
conversation_members	conversation_id, user_id, last_read_sequence	UNIQUE conversation/user
messages	conversation_id, sender_id, client_message_id, sequence, body, state	UNIQUE sender/client_message_id; UNIQUE conversation/sequence
uploads	owner_id, region, object_key, size, mime, scan_state, expires_at	UNIQUE object_key; scan_state/expiry
reviews	order_id, author_id, subject_id, stars, text, state, publish_at	UNIQUE order/author/subject; CHECK stars 1–5
blocks	blocker_id, blocked_id, scope, created_at	UNIQUE blocker/blocked/scope; no self-block
cases	reporter_id, target_type, target_id, kind, status, priority	status/priority/time; target index
case_evidence	case_id, reference, snapshot_hash, retention_until	case/time; immutable snapshot

Сущность	Основные поля	Ключи и ограничения
moderation_dictionaries и rules	country, language, version, effective_at, scope, state; token/phrase, exceptions	UNIQUE scope/version; no arbitrary regex
moderation_episodes, matches, auto_holds	content_id/revision, policy_snapshot, user_id, case_id; дочерние rule/version/context; expires_at	UNIQUE content/revision/snapshot; один case/hold на episode; expiry job; audit
sanctions	user_id, scope, starts_at, ends_at, reason, case_id	user/scope/time
plans и price_versions	product_type=subscription/boost/promo, capabilities, period; country, currency, provider, SKU, dates	UNIQUE provider/SKU/version; no overlapping published window
subscriptions	user_id, provider, original_transaction_id, state, expires_at	UNIQUE provider/original_transaction_id
payment_transactions	provider, transaction_id, type, amount, currency, original_id	UNIQUE provider/transaction_id/type; append-only
entitlement_grants	user_id, scope, source_type, source_id, valid_from, valid_until, balance	UNIQUE source/scope; user/scope/time
entitlement_consumptions	grant_id, action, target_id, idempotency_key	UNIQUE grant/idempotency_key
ad_sessions	user_id, provider, nonce_hash, placement, policy_version, expires_at, state	UNIQUE nonce_hash; user/time
ad_rewards	session_id, network_transaction_id, grant_id, verified_at	UNIQUE network/transaction; UNIQUE session/reward_kind
push_campaigns и recipients	audience, locale payload, deeplink, send_at, zone, state; user, event_id, result	UNIQUE campaign/user/event; consent checked at send
promotions	plan_id, scope, audience, valid_from, end_exclusive, zone, next_price_id, state, version	Один published interval на scope; UNIQUE promotion/user grant
monetization_configs	country, role, platform, banner_ads_enabled, rewarded_access_enabled, reward_policy, version, effective_at, state	UNIQUE scope/version; один effective config на момент
ad_revenue_reports	network, period, country, currency, amount, state, fetched_at	UNIQUE provider/report/revision; estimated/finalized
campaigns и creatives	country, locale, dates, state, budget; asset_id, destination	state/country/dates; moderated creative version
verification_checks / identity_documents	user_id, country, document_revision, encrypted_object_ref, result, reviewer, expiry, reason, retention_until	Private region store; revision/state checks; sensitive access audit
user_blacklist_entries	user_id, case_id, scope, reason, evidence_refs, starts/ends, status, decision_actor	Manual decision; scope/status; no public fraud label
support_threads / support_messages	user_id nullable, region, case_id, recovery_capability_hash, expires_at, last_activity, seq, attachments, state	Participant ACL; sender/message dedupe; anonymous TTL/rate limit
privacy_requests	user_id, type, state, due_at, completed_at, hold_reason	state/due_at

Сущность	Основные поля	Ключи и ограничения
security_events и admin_audit	actor, action, target, reason, time, request_id	time/actor/region; retention partition
outbox и webhook_inbox	event_id, aggregate_id, version, payload, state, attempts	UNIQUE event_id; pending/time

Ledger и outbox не заменяют бизнес-таблицы. Списание рекламного action credit, создание действия и outbox находятся в одной транзакции. PostgreSQL ограничения являются последней защитой при retry и конкурентной обработке.

Event payload не должен копировать полный профиль, документы или адрес. Ссылка на объект и безопасный event type достаточны; потребитель читает нужные поля с разрешениями. Для больших message/audit таблиц заранее предусмотреть partitioning по времени, проверив последствия FK и удаления.

Миграции forward-only с expand–migrate–contract. Удаление столбца происходит после вывода старых клиентов и проверки rollback window. Номер схемы, миграции, seed справочников и диаграмма связей входят в репозиторий.

27 Общие правила HTTP API

FR-029 P1. Базовый путь /api/v1. JSON UTF-8, UUID в строках, время RFC 3339 UTC, язык через явную locale/Accept-Language. OpenAPI 3.1 описывает каждый маршрут, DTO, enum, security и ошибку; клиентские контракты генерируются/проверяются в CI.

Access token передается Authorization: Bearer. Клиент не передает role, user_id владельца или регион как доверенный источник полномочий. Сервер берет владельца из сессии и применяет object-level policy. Публичные auth, legal и provider webhook маршруты имеют отдельную схему защиты.

Изменяющие бизнес-команды используют Idempotency-Key. Запись связывает account, method, route, body hash и результат. Такой же ключ с другим телом → 409 IDEMPOTENCY_CONFLICT. Предложенное хранение обычных ключей 24 часа; для платежей и рекламных операций провайдерская уникальность сохраняется весь требуемый учетный срок.

Конкурентные изменения используют If-Match: version либо expected_version. HTTP 412/409 возвращает current_version, не выполняя частичный переход. Пагинация: limit 1–100, cursor непрозрачен и привязан к фильтрам; сортировка стабильна. PATCH принимает только разрешенные поля, отсутствующее поле отличается от explicit null.

Успех: data и при необходимости meta {request_id, next_cursor, server_time}. Ошибка: error {code, message, details, request_id, retryable}; details не содержит секретов и чужих полей. Пример: {"error":{"code":"ENTITLEMENT_REQUIRED","message":"Нужен действующий доступ","details":{"capability":"send_offer"},"request_id":"req_demo","retryable":false}}.

Коды: 400 VALIDATION_ERROR; 401 UNAUTHENTICATED/TOKEN_EXPIRED; 403 FORBIDDEN/COUNTRY_DISABLED/ENTITLEMENT_REQUIRED; 404 NOT_FOUND; 409 STATE_CONFLICT/OFFER_CHANGED/REVISION_NOT_ACKNOWLEDGED/IDEMPOTENCY_CONFLICT; 413 FILE_TOO_LARGE; 422 POLICY_REJECTED; 429 RATE_LIMITED; 503 PROVIDER_UNAVAILABLE. Где раскрытие существования объекта опасно, возвращать одинаковый 404.

Каждый запрос получает request_id, latency metric и безопасный trace context. Тела auth, ID-check и платежные подписи не логируются. Таймауты и retry отражены в API; нельзя повторять неидемпотентную команду вслепую.

Дата прекращения поддержки версии API объявляется заранее; мобильный клиент получает minimum_supported_version и причину обновления. Даже устаревшему клиенту сохраняется доступная веб-альтернатива для privacy и поддержки.

28 API аккаунта профиля и поиска

Обозначения доступа: P — публично с rate limit; U — активная сессия; E — U и capability; V — действующий passed executor_verified; S — служебная роль. На всех U/E маршрутах проверяется object policy. Country stop_new_business применяется к новым коммерческим действиям, но не к privacy/support, управлению подпиской и разрешенным действиям уже активного заказа.

Метод и путь	Доступ	Назначение и результат
POST /auth/register	P	Телефон E.164 и пароль в выбранном регионе; unverified phone, tokens + onboarding
POST /auth/login	P	Телефон + пароль, neutral errors, rate limit, новая сессия
POST /me/password/change	U + current password	Новый Argon2id hash; отзыв других сессий
POST /auth/refresh	P	Ротация refresh → новая пара; replay отзывает family
POST /auth/logout-all	U + reauth	Отзыв всех refresh families и WebSocket-сессий
POST /auth/logout	U	Отзыв текущей сессии; 204
GET /me/sessions	U	Собственные устройства и события входа
DELETE /me/sessions/{id}	U	Отзыв своей сессии; idempotent
POST /me/phone-change-requests	U + current password	Замена только собственного логина; новый номер тоже unverified; без присвоения чужого аккаунта
GET/PATCH /me	U	Профиль и разрешенные редактируемые поля
GET /legal/documents	P	Версии по стране/языку/типу
POST /me/consents	U	Согласие с точной version/hash
POST /me/privacy-requests	U + reauth	Export/delete → job ID
GET /me/privacy-requests/{id}	U	Статус собственного запроса
GET /catalog/categories	U	Переводы и schema полей страны
GET /geo/cities	U	Справочник и поиск города
GET /contractors	E	Фильтры, cursor, безопасные карточки
GET /top-listings	E; orders + V	Country/city/category/type, rank snapshot, organic items и marked promotions
PUT/DELETE /listing-votes/{type}/{id}	E + non-owner	Like/dislike либо убрать; одна active reaction, version/idempotency
GET /customers/{id}	E/участник	Безопасная карточка заказчика, репутация и проверенные факты

Метод и путь	Доступ	Назначение и результат
GET /contractors/{id}	E	Публичная версия профиля без секретных полей
PUT /me/contractor-profile	U	Черновик собственного профиля с version
POST /me/contractor-profile/publish	E + V	Проверки и published/pending_review
GET /contractors/{id}/portfolio	Как профиль	Только published safe revisions, cursor и безопасные variants
GET/POST /me/portfolio-projects	U	Собственный список либо создать draft
GET/PATCH/DELETE /me/portfolio-projects/{id}	Владелец	Read/update revision либо archive/retention; expected_version
POST /me/portfolio-projects/{id}/submit	Владелец + E + V	Проверки текста/фото/прав → pending_review
PUT /me/portfolio-projects/order	Владелец	Атомарный reorder IDs и expected_version
POST /uploads/initiate	U	Filename/mime/size/purpose → upload ID и scoped URL
POST /uploads/{id}/finalize	U	Проверка загрузки → quarantine/scan status
POST /me/verification-sessions	U + consent	Страна/type/required pages → private upload/review session
POST /me/verification-sessions/{id}/submit	Владелец	Safe uploads + revision → pending_review; без auto-verified
GET /me/verification	U	Статус, срок и понятная причина

Пример поиска: GET /contractors?country=RS&category_id={uuid}&city_id={uuid} &radius_m=10000&work_mode=onsite&limit=20. Координаты, если нужны, отправляются только в защищенном запросе и исключаются из access logs; точное положение не включается в shareable URL.

Пример profile DTO: {"expected_version":3,"headline":"Ремонт сантехники","category_ids": ["uuid"],"work_modes":["onsite"],"service_area":{"city_id":"uuid","radius_m":10000},"price": {"mode":"hourly","amount_minor":250000,"currency":"RSD"}}. Значения демонстрационные, не реальный тариф и не личные данные.

Verification endpoint проверяет согласие, законность country flow и актуальную ревизию; повторный callback возвращает прежний результат. Local PIN/биометрия не имеют endpoint выдачи серверного access token. Auth recovery endpoints не вводятся до утверждения D17 и отсутствуют как небезопасные заглушки. Endpoint удаления аккаунта не выполняет удаление до reauth и не заставляет сначала приобретать подписку.

29 API заказов приглашений и откликов

Метод и путь	Доступ	Команда или результат
POST /orders	U	Создать собственный draft; body по schema категории
GET /orders	E + V	Только доступные open-заказы с фильтрами/cursor

Метод и путь	Доступ	Команда или результат
GET /me/orders	U	Собственные заказы; история доступна после expiry
GET /orders/{id}	U/E	Участник по scope; посторонний только доступная карточка
PATCH /orders/{id}	Владелец	Новая revision, expected_version; права по state
POST /orders/{id}/publish	E + владелец	draft → open/pending_moderation
POST /orders/{id}/extend	E + владелец	Только до expires_at, без выхода из terminal
POST /orders/{id}/clone	E + владелец	Новый draft с новым ID
POST /orders/{id}/invites	E + владелец	Пригласить contractor_id к конкретному заказу
GET /me/order-invites	U	Полученные приглашения и статусы
POST /order-invites/{id}/respond	Получатель; accept + V	accept/decline; accept открывает отклик
POST /order-invites/{id}/revoke	Владелец заказа	Отзыв pending-приглашения
POST /orders/{id}/offers	E + исполнитель + V	active offer, revision и acknowledged_order_revision
GET /orders/{id}/offers	Владелец	Только собственный заказ, безопасные профили
PATCH /offers/{id}	Автор + E + V	Новая offer revision до выбора
POST /offers/{id}/acknowledge	Автор + E + V	Подтверждение конкретной order revision
POST /offers/{id}/withdraw	Автор	Отзыв active-отклика
POST /orders/{id}/select-offer	Владелец + E	Атомарный выбор; V выбранного исполнителя
POST /orders/{id}/start	Выбранный исполнитель	assigned → in_progress
POST /orders/{id}/request-completion	Выбранный исполнитель	Результат → completion_requested
POST /orders/{id}/confirm-completion	Заказчик	completion_requested → completed
POST /orders/{id}/request-revision	Заказчик	Причина доработки → in_progress
POST /orders/{id}/cancel	Владелец	open → cancelled; причина и expected_version
POST /orders/{id}/cancel-requests	Участник	Создать запрос отмены после выбора
POST /cancel-requests/{id}/respond	Другой участник	accept/reject; конфликт → case
POST /orders/{id}/amendments	Участник	Предложить новые существенные условия
POST /amendments/{id}/respond	Другой участник	Подтвердить/отклонить точную revision

Пример выбора: POST /orders/{id}/select-offer; заголовки Authorization, Idempotency-Key и If-Match. Body: {"offer_id":"uuid","offer_revision":2,"order_revision":4}. Ответ: {"data": {"order_id":"uuid","status":"assigned","version":5,"assignment_id":"uuid","conversation_id":"uuid"}}.

Пример создания: {"category_id":"uuid","country":"RS","city_id":"uuid","title":"Установить смеситель","description":"Нужна установка предоставленного смесителя","work_mode":"onsite","budget":{"mode":"negotiable","currency":"RSD"},"time_window": {"start":"2026-11-02T08:00:00Z","end":"2026-11-02T16:00:00Z","time_zone":"Europe/Belgrade"},"upload_ids":[]}.

Отдельный endpoint GET /public/country-capabilities допускается без аккаунта для bootstrap. Все числовые лимиты и схемы формы возвращаются версионированной конфигурацией; сервер все равно проверяет их независимо от клиента.

30 API общения репутации и поддержки

Метод и путь	Доступ	Результат и защита
GET /me/conversations	U	Собственные треды с безопасным preview
GET /conversations/{id}/messages	Участник	after_sequence/cursor, без пропусков
POST /conversations/{id}/messages	Участник + scope	client_message_id, text/upload IDs; dedupe
PATCH /messages/{id}	Автор	Ограниченное окно и история версии
DELETE /messages/{id}	Автор	Tombstone по политике, evidence не уничтожается
POST /conversations/{id}/read	Участник	max sequence, монотонное обновление
GET /uploads/{id}/download	Разрешенный участник	Короткий signed URL после scan
POST /orders/{id}/reviews	Участник	Проверка completed и unique pair
PATCH /reviews/{id}	Автор	Разрешенное окно, повторная модерация
GET /users/{id}/reviews	E/участник	Только published и доступные по scope
POST /me/blocks	U	target_user_id, личная блокировка
DELETE /me/blocks/{targetId}	U	Снять собственную блокировку
POST /reports	U	target, reason, text, upload IDs → case ID
GET /me/cases	U	Собственные обращения с публичным состоянием
POST /cases/{id}/messages	Участник дела	Дополнение доказательств, scan и лимиты
POST /cases/{id}/appeals	Адресат решения	Причина, доказательства; контроль срока
POST /support/threads	U	Собственный встроенный чат поддержки, без подписки
GET /me/support-threads	U	История собственных обращений
GET/POST /support/threads/{id}/messages	Участник	Cursor/seq, client_message_id, safe attachments
POST /public/recovery-threads	P + anti-abuse	Region-first; opaque ticket + secret capability; без account enumeration
GET/POST /public/recovery-threads/{id}/messages	Recovery capability	Только этот ограниченный pre-login чат; не доступ к аккаунту
GET /me/notifications	U	Durable inbox, cursor, unread count
POST /me/notifications/{id}/read	U	Идемпотентно отметить собственное событие
POST /me/notifications/read-all	U	До заданного server cursor, без гонки с новыми событиями
GET/PATCH /me/notification-preferences	U	Категории и quiet hours
POST /me/push-tokens	U	Token, platform, environment; привязка к сессии
DELETE /me/push-tokens/{id}	U	Отвязать собственное устройство

Пример сообщения: {"client_message_id":"uuid","text":"Могу приехать в согласованное время","upload_ids":[]}. Ответ содержит id, sequence, created_at и delivery_state=sent. Повтор возвращает исходное сообщение даже при другом сетевом соединении; отличающееся тело с тем же client ID вызывает конфликт.

Пример жалобы: {"target_type":"message","target_id":"uuid","reason_code":"threat","description":"Описание конкретного нарушения","upload_ids":[]}. Пользователь не передает moderator_id, sanction_type или внутренний priority. Номер дела не дает доступ к чужому делу.

WebSocket события: order.updated, offer.created, offer.updated, invite.created, message.created, message.updated, conversation.read, review.published, case.updated, entitlement.changed, notification.created, config.changed, support.message.created, support.status.changed. Recovery thread подписывается отдельно по его capability, без доступа к account events. Envelope: event_id, type, aggregate_id, aggregate_version, occurred_at и data с минимальными полями. Подписки проверяются при открытии и при изменении membership.

Heartbeat соединения и reconnect с backoff/jitter не должны расходовать marketplace-кредиты. Отсутствие сети сохраняет черновик сообщения локально; отправка после восстановления требует повторной проверки состояния чата. Просроченная сессия показывает login, но не теряет несекретный локальный текст черновика без предупреждения.

31 API монетизации административные команды и задания

Метод и путь	Доступ	Назначение
GET /me/monetization-config	U	Effective flags, promotion/end/next price, scope, version, ETag, TTL
GET /boost-offers	E	Target/placement/duration, capacity, актуальная цена/SKU
POST /boost-reservations	E + owner	Capacity hold и snapshot; service card + V
POST /boost-purchases/verify	U + owner	Receipt + reservation, provider verification и dedupe
GET /me/boosts	U	История и pending/active/paused/resolution, сроки и provenance
POST /admin/boost-grants	Promotion + approval	Free admin grant, reason/duration/capacity, no fake payment
POST /admin/boost-grants/{id}/decision	Promotion + reason	Pause/revoke/extend через versioned policy и audit
GET /admin/boost-reports	Billing/Promotion	Paid/admin grants, capacity, receipts/refunds, freshness
POST /admin/ranking-configs	Content	Draft/preview versioned window/formula/criteria
POST /admin/ranking-configs/{id}/publish	Content + approval	Validated effective version и audit
POST /admin/placement-policies	Promotion	Draft scope/capacity/rotation/schedule
POST /admin/placement-policies/{id}/validate	Promotion	Preview влияния на reservations/grants
POST /admin/placement-policies/{id}/publish	Promotion + approval	Не уменьшать емкость ниже обещанной; version/effective_at

Метод и путь	Доступ	Назначение
GET /me/entitlements	U	Effective capabilities, источники, expiry и order scopes
GET /billing/offers	U	Доступные provider/SKU по стране и платформе
POST /billing/verify-purchase	U	Проверка transaction reference на сервере
POST /billing/restore	U	Восстановление подтвержденной собственной покупки
GET /me/subscriptions	U	Подписка, срок и инструкция управления
POST /billing/refund-requests	U	Обращение; не фиктивный refund без провайдера
POST /webhooks/billing/{provider}	Подпись провайдера	Durable inbox, dedupe, replay protection
POST /ads/reward-sessions	U	Проверка политики/лимитов → одноразовая сессия
GET /ads/reward-sessions/{id}	Владелец	pending/verified/granted/failed/expired
GET/POST /webhooks/ads/{provider}	SSV провайдера	Проверяемая награда, unique transaction
GET /admin/users	S	Scoped поиск по разрешенным ID/телефону/стране/городу
GET /admin/users/{id}	S + field permissions	FR-041 карточка/история без email; audited sensitive reads
GET /admin/users/{id}/security-events	Security	Полные IP/time/device/session; фильтры и аудит
GET /admin/users/{id}/cases	Support/ Moderator	Поиск по истории заказов/жалоб/санкций
POST /admin/users/{id}/blacklist	Senior + reason	Manual case/evidence/scope/duration, notify/appeal
POST /admin/blacklist/{id}/decision	Senior + reason	Release/extend/overturn, конечный срок, version/audit
POST /admin/users/{id}/deletion-requests	Privacy + approval	Отдельный preview/retention process, не ban
POST /admin/verifications/{id}/decision	Verification reviewer	Decision + exact revision, причина, срок, audit
POST /admin/verifications/{id}/document-url	ID-view + MFA	Короткая ссылка на разрешенную revision, sensitive-read audit
GET /admin/support-threads	Support	Очередь/назначение, ограниченный контекст
POST /admin/support-threads/{id}/messages	Назначенный support	Ответ от поддержки, не от имени пользователя
POST /admin/support-threads/{id}/commands	Support + version	Assign/reassign/resolve/reopen по state machine
GET/POST /admin/support-threads/{id}/internal-notes	Support internal-note ACL	Отдельные записи, никогда не возвращаются пользователю
POST /admin/users/{id}/sanctions	S + причина	Санкция и связанное дело
POST /admin/cases/{id}/resolve	S	Решение из разрешенного enum
POST /admin/cases/{id}/appeal-decision	Senior	Независимая финальная апелляция

Метод и путь	Доступ	Назначение
POST /admin/categories/{id}/versions	Content	Черновик дерева/переводов/схемы
POST /admin/price-versions	Billing	Черновик versioned цены и SKU
POST /admin/price-versions/{id}/publish	Billing + approval	Проверка провайдера и effective date
POST /admin/monetization-configs	Billing	Draft рекламных флагов, роль, страна, платформа, награда и лимиты
POST /admin/monetization-configs/{id}/validate	Billing	Provider/policy/SKU checks и preview влияния
POST /admin/monetization-configs/{id}/publish	Billing + approval	effective_at, атомарная версия, audit
POST /admin/monetization-configs/{id}/rollback	Billing + approval	Новая версия прежних правил, без отмены grants
POST /admin/campaigns	Campaign	Страна, аудитория, срок, креатив, лимиты
POST /admin/campaigns/{id}/approve	Отдельное право	Проверенный креатив и законность категории
POST /admin/promotions	Billing	Draft нулевого периода и следующей цены подписки
POST /admin/promotions/{id}/publish	Billing + approval	Preview, exclusive UTC boundary, SKU validation и schedule
POST /admin/promotions/{id}/cancel	Billing + approval	Остановить новые grants, сохранить выданные обещания
POST /admin/push-campaigns	Campaign + push permission	Draft сегментов, текста, времени и allowlist deep link
POST /admin/push-campaigns/{id}/preview	Push manager	Аудитория, consent/suppression, язык и целевой экран
POST /admin/push-campaigns/{id}/test	Push manager	Только разрешенные тестовые получатели
POST /admin/push-campaigns/{id}/schedule	Push manager + approval	Зафиксировать version и время отправки
POST /admin/push-campaigns/{id}/cancel	Push manager	Остановить еще не отправленные сообщения
GET /admin/push-campaigns/{id}/stats	Push manager	queued/sent/failed/opened, без ложного delivered
GET /admin/ad-revenue	Billing/Campaign	Период, сеть, страна, валюта, estimated/finalized, revision, freshness
POST /admin/moderation-dictionaries	Moderator manager	Draft правил/исключений по стране и языку
POST /admin/moderation-dictionaries/{id}/preview	Moderator manager	Validate, dry-run совпадений и false-positive review
POST /admin/moderation-dictionaries/{id}/publish	Senior + approval	Версия/effective_at; без ретроактивного массового бана
GET /admin/moderation-matches	Moderator	Минимальный контекст и открытые auto holds по scope
POST /admin/auto-holds/{id}/decision	Moderator/Senior	Release/extend/manual sanction с причиной и version
POST /admin/brand-icons	Content	Приватный upload intent, MIME/лимиты launcher-исходника
POST /admin/brand-icons/{id}/versions	Content	Finalize, scan, crop, preview и platform variants

Метод и путь	Доступ	Назначение
POST /admin/brand-icons/{id}/approve	Brand owner	Утвердить исходник для сборки; без store release
POST /admin/brand-icons/{id}/generate	Release role	Идемпотентное задание iconset по immutable version
GET /me/referrals	U	Код/link, правила campaign snapshot, прогресс, награды/expiry
POST /referrals/attribute	U	Код, first-valid attribution, unique invited user
POST /me/referral-rewards/{id}/redeem	U	Idempotency, provider eligibility, собственная награда
POST /admin/referral-campaigns	Campaign + Billing	Draft version, условия/порог/лимиты/provider offer
POST /admin/referral-campaigns/{id}/publish	Campaign + approval	Validate/preview, schedule, атомарная budget policy
POST /admin/referral-campaigns/{id}/stop	Campaign + approval	Остановить новые атрибуции, сохранить обещанные snapshots
GET /admin/referral-reports	Campaign/Billing	Воронка, ledger, бюджет, anomalies и freshness
GET /admin/audit	Auditor	Scoped неизменяемая история

Отчеты рекламной сети импортируются ежедневно либо по доступности провайдера; повторно сверяются незавершенные периоды до finalized и последующие корректировки по контракту. Report ID + revision идемпотентны, новая revision не суммируется со старой как новый доход. Сохраняются source timestamp, fetched_at, валюта и статус; ошибка показывает stale/no-data, а не ноль подтвержденной выручки. Finalized отчет сети не является доказательством поступления денег на банковский счет.

Background jobs и предлагаемые интервалы: outbox delivery непрерывно; expiration заказов/откликов/наград и auto moderation holds каждую минуту; повтор webhook с backoff до dead-letter; reconciliation подписок ежедневно и по конфликту; publication отзывов и ranking snapshot каждые 5 минут; expiry boost reservations/grants каждую минуту; scan файлов по событию; cleanup незавершенных загрузок каждый час; retention/delete ежедневно; backup по расписанию раздела 38.

Каждый job имеет job ID, deduplication key, ограничение попыток, timeout, metrics и dead-letter reason. Повторная обработка не выполняет второе списание и не публикует второй отзыв. Неуспешное задание после лимита создает алерт и видимую задачу оператора; перенос в dead-letter не считается успешной бизнес-операцией.

Пример entitlement: {"capabilities":["search_full","publish_order","send_offer"],"valid_until":"2026-11-03T12:00:00Z","sources":[{"type":"subscription","status":"active"}],"order_scopes":[{"order_id":"uuid","capabilities":["chat","complete","report"]}]}.

Debug-проверка receipt и выдача test grant допустимы только в non-production. Production не содержит маршрутов «дать подписку по user_id» без привилегии, аудита, причины и утвержденного сценария компенсации.

32 Реестр экранов входа поиска и профиля

FR-030 P1. Для каждого экрана обязательны loading, error с повтором, empty где применимо, offline, session expired и доступность. Валидация поля выводится рядом и озвучивается screen reader; server error сохраняет введенные допустимые значения. Реальные дизайн-макеты создаются на этапе UX, это ТЗ не выдает перечень экранов за готовый дизайн.

ID и экран	Поля и действия	Специальные состояния
S01 Старт и регион	Страна, язык, legal links, продолжить	Страна disabled, сохраненный region hint
S02 Регистрация и вход	Номер с кодом страны, пароль, показать/скрыть, зарегистрироваться/войти, помощь	Без SMS, номер занят, нейтральная ошибка, backoff
S03 Условия	Версии, отдельные согласия, возрастное подтверждение	Изменившаяся версия, отказ
S04 Первичный профиль	Имя, аватар, роли, сохранить	Scan pending, ошибка фото
S05 Выбор доступа	Реальная цена/период, награда, restore, privacy/support	Нет провайдера, no-fill, pending purchase
S06 Главная заказчика	Категории, поиск, город, создать заказ	Нет страны/каталога, offline cache
S07 Поиск исполнителей	Запрос, фильтры, сортировка, список/карта	Нет результатов, GPS denied, map failure
S08 Карточка исполнителя	Услуги, цены, портфолио, отзывы, зона, предложить заказ	Profile paused, pair block, entitlement expiry
S09 Главная исполнителя	Заказы по категориям, фильтр места	Нет подходящих заказов, роль не настроена
S10 Карточка заказа	Описание, бюджет, срок, примерный адрес, отклик	Заказ закрыт, условия изменились
S11 Мой профиль	Публичный preview, контакты, редактирование	Незавершенный onboarding, restrictions
S12 Услуги исполнителя	Категории, описание, цены, зона, галерея, перейти к портфолио	Pending review, rejected fields
S13 Документ исполнителя	Обязательный ID/паспорт по стране, страницы, upload/submit, статус	Pending/rejected/resubmit/expired; отказ сохраняет customer/support доступ
S14 Отзывы пользователя	Звезды, количество, критерии, текст	Нет отзывов, скрытый текст, спор
S38 Мое портфолио	Проекты, добавить/изменить/удалить, фото/crop/обложка, порядок, submit	Draft/scan/review/rejected/archived, expiry, conflict, quota
S39 Проект и фото	Описание, категория, значок связи с заказом, lightbox/swipe, пожаловаться	Нет фото, недоступный проект, offline, alt text/zoom controls
S41 Топ-100	Тип/страна/город/категория, popular/new, like/dislike, профиль/заказ	Empty, rank stale, vote conflict, marked promotion, no self-vote
S42 Продвинуть объявление	Собственный target, место/срок, реальная цена, checkout, история	Нет мест/провайдера, pending receipt, invalid target, refund/support
S40 Поддержка и recovery chat	Регион до login, новый чат, до login только текст; после auth вложения/история	Anonymous capability expired, rate limit, reconnect; no account enumeration
S15 Безопасность	Сессии/revoke, смена пароля, настройка PIN/биометрии	PIN limit, biometric unavailable/changed, full reauth

Навигация после входа: главная, поиск/заказы, сообщения, уведомления, профиль. Переключение роли сохраняет один аккаунт и общую подписку; несохраненные формы предупреждают о выходе. Глубокие ссылки ведут на объект после проверки авторизации, региона и доступа; закрытый объект показывает понятную причину.

Адаптивность: проверить компактные телефоны, крупные телефоны, планшеты и крупный системный текст. Нельзя прятать подтверждение условий за клавиатурой. Интерактивные зоны не менее рекомендаций платформы, предлагаемый минимум 44pt iOS/48dp Android; контраст текста соответствует WCAG AA. Основное действие не зависит только от цвета.

33 Реестр экранов сделки общения и поддержки

ID и экран	Поля и действия	Специальные состояния
S16 Черновик заказа	Категория, текст, место, срок, бюджет, фото, preview	Validation, upload pending, локальный draft
S17 Публикация	Снимок заказа, право, опубликовать	Moderation, duplicate retry, limit
S18 Мои заказы	Вкладки состояний, сроки, перейти, clone	Empty, expired, suspended
S19 Приглашение исполнителю	Свой open-заказ, отправить, revoke	Нет заказов, block, cooldown
S20 Входящие приглашения	Заказ, срок, принять/отказать	Revoked, expired, изменившийся заказ
S21 Отклик	Сообщение, цена, время, срок, подтвердить ревизию	Offer exists, quota, order revision conflict
S22 Список откликов	Условия, рейтинг, уточнить, выбрать	Нет откликов, withdrawn, changed offer
S23 Выбор исполнителя	Обе revision, цена, срок, подтвердить	Конкурентный выбор, право истекло
S24 Рабочий заказ	Условия, прогресс, начать, изменить, отменить	Amendment pending, sanction, dispute
S25 Чат	Текст, файлы, статусы, report/block	Offline queue, scan fail, frozen thread
S26 Завершение	Результат, фото, принять/доработать	Нет ответа, escalation, closed_unconfirmed
S27 Отмена	Причина, последствия, отправить/ответить	Оспорена, дело, уже завершено
S28 Оценка	Звезды, критерии, текст, preview	Window expired, double blind, review hold
S29 Жалоба	Тип, описание, доказательства, отправить	Duplicate case, unsafe file, rate limit
S30 Мои обращения	Номер, статус, сообщения, апелляция	Waiting for user, deadline, final decision
S31 Уведомления	События, прочитано, настройки	Нет событий, ссылка на недоступный объект
S32 Мой доступ	Источники, сроки, управление подпиской, restore	Grace, retry, revoked, country unavailable
S33 Рекламная награда	Условия, запуск, pending, итог	Skip, no fill, callback delay, cap
S34 Приватность	Согласия, экспорт, удаление, документы	Reauth, legal hold, export ready/expired
S36 Локальная разблокировка	PIN или доступная системная биометрия, полный вход	Сессия отозвана, 5 ошибок, key invalidated; нет SMS
S37 Приглашения и бонусы	Share link/code, правила, прогресс/pending, награды/expiry, redeem	Недопустимый код/self-invite, ожидание, provider unavailable, appeal
S35 Настройки	Язык, страна, уведомления, выход	Смена региона требует процесса, offline

Все действия выбора, отмены, блокировки и удаления объясняют последствия до подтверждения. Оплата показывает сумму, валюту, период, автопродление, условия отмены и реальный магазинный экран. Кнопка «Восстановить» не запускает новую покупку.

Для завершения после expiry используется order-scoped доступ, без перенаправления на paywall. Если чат закрыт из-за угроз, пользователь видит доступный контакт поддержки и сохраненную историю, а не кнопку оплатить для продолжения контакта.

Публичный сайт P1: W01 описание и страны; W02 поддержка; W03 правовые документы по языку; W04 удаление аккаунта; W05 статус доступности/maintenance. Публичные формы защищены от спама, не собирают документы личности в обычное поле сообщения и не требуют подписки.

34 Реестр административных экранов и UX приемка

ID и экран	Поля и действия	Контроль
A01 Вход сотрудника	SSO/MFA, повторная аутентификация	Нет общего user login, session timeout
A02 Дашборд и ad revenue	Страна, период, сеть, валюта, estimated/finalized, revision и время сверки	Stale/no-data, SSV отдельно от денег, отсутствие PII
A03 Пользователи	Страна/город/телефон, IP/time/devices, заказы/жалобы/история, blacklist/delete	Field RBAC, IP geo approximate, no email, reason/audit
A04 Заказ и история	Ревизии, assignment, events, дела	Read-only условия, корректный timeline
A05 Очередь модерации	Профили/портфолио/контент, приоритет, назначение, решение	Нет self-review финальной апелляции
A06 Дело и апелляция	Evidence, сообщения, правила, outcome	Минимальные права, неизменяемые снимки
A07 Проверка документов	Страна/type/revision, защищенный просмотр, approve/reject/resubmit	MFA, sensitive-read audit, exact revision, retention
A08 Категории и языки	Дерево, schema, перевод, preview	Проверка циклов, обязательных переводов
A09 Планы цены и промо	Страна, валюта, SKU, нулевой период, end/time zone, следующая цена, audience	Preview/schedule/publish, provider sync, сохранение выданных прав
A16 Подписка и реклама	Независимые banner/rewarded флаги, preview, schedule, publish, rollback	Подписка сохраняется, права и pending rewards защищены
A10 Кампании	Креатив, destination, страна, сроки, лимиты	Moderation, malware/link review, stop
A11 Privacy очередь	Export/delete, due date, hold reason	Повторная проверка основания, audit
A12 Security события	Телефон при праве, время, полный IP, device/session	IP geo approximate; GPS permission metadata; no email
A13 Аудит	Actor, action, target, request ID	Нет изменения/скрытого удаления
A14 Country capabilities	Провайдер, состояние, evidence, дата проверки	P0 gate, feature flag rollback
A17 Push-кампании	Сегменты, локали, deep link, preview/test/schedule/cancel и результаты	Consent, allowlist, frequency cap, audit
A18 Запрещенные слова	Страна/язык, слова/фразы, исключения, scope, dry-run, publish и matches	Без regex, auto hold expiry, human decision, audit
A19 Иконка приложения	Upload, auto/manual crop, iOS/Android preview, approve/generate, build status	MIME/scan/pixel limits, safe zone; новый релиз отдельно

ID и экран	Поля и действия	Контроль
A20 Реферальные кампании	Порог/событие/бонус, scope, сроки, бюджет, preview/publish/stop, отчет	Provider eligibility, stacking, dedupe, fraud review, snapshot
A22 Топ и продвижение	Algorithm preview/version, placements/capacity, цены/SKU, paid/admin grants	Нет покупки organic rank, reason/audit, overlap/provider/country gates
A21 Поддержка и recovery	Очередь чатов, назначение, ответы, internal notes, case links	Anonymous text-only ACL, private notes, ownership proof policy
A15 Jobs и интеграции	Dead-letter, reconciliation, retry	Идемпотентность, scoped operator rights

UX приемка проходит по полным сценариям и всем языкам. Проверить отображение длинного казахского и сербского текста, валют, десятичных разделителей, форм множественного числа, локальных адресов и часовых поясов. Не использовать национальный флаг как единственный выбор языка.

Offline режим P1 разрешает читать ограниченный кэш и готовить локальные черновики. Нельзя офлайн подтвердить оплату, выдать награду, выбрать исполнителя, опубликовать заказ или отправить финальную оценку. После reconnect пользователь видит конфликт ревизий и явный выбор актуальной формы; данные не перетираются молча.

Доступность: VoiceOver/TalkBack, логичный focus order, семантические label, текстовые ошибки, доступные таймеры, reduced motion, системный размер шрифта до 200% без потери основных действий. Для web использовать клавиатуру без мыши и видимый focus; таблицы имеют корректные headers.

Выход, смена аккаунта и отзыв сессии очищают приватные данные прошлого пользователя. Скриншоты экрана платежа/документа и превью task switcher оцениваются в threat model; нельзя обещать универсальную защиту от скриншотов на всех платформах.

35 Нефункциональные требования и целевая нагрузка

Следующие значения — предлагаемые критерии приемки на согласованном стенде, а не измеренные свойства текущего репозитория. До нагрузочных тестов утвердить профиль трафика, регион, размеры инстансов, объем данных и стоимость; отчет обязан содержать эти условия.

ID	Целевой показатель P1	Как измерять
NFR-01	99,5% доступности API за месяц, кроме заранее согласованных работ	Синтетические проверки каждого региона
NFR-02	p95 чтения ≤ 500 мс, p99 ≤ 1 500 мс	На ingress, без времени сети клиента
NFR-03	p95 поиска с геофильтром ≤ 800 мс	100 тыс. профилей и 500 тыс. заказов в fixture
NFR-04	p95 обычной записи ≤ 700 мс	Без ожидания внешнего checkout/ID check
NFR-05	p95 появления сообщения у online адресата ≤ 2 с	Два реальных клиента, региональный путь
NFR-06	100 запросов/с устойчиво 60 минут; пик 300/с 5 минут	Смешанный сценарий; ошибки < 1%, без потери записей

ID	Целевой показатель P1	Как измерять
NFR-07	2 000 активных WebSocket соединений на региональном стенде	Reconnect storm и fan-out с лимитами
NFR-08	99% из outbox обработаны ≤ 60 с при штатной работе	Возраст backlog; без гарантий внешней доставки
NFR-09	RPO ≤ 15 минут, RTO ≤ 4 часов	Фактический restore drill, не только наличие backup
NFR-10	Crash-free sessions ≥ 99,5% на пилоте	Версия/платформа, privacy-safe telemetry
NFR-11	Первый полезный экран ≤ 3 с на согласованном среднем устройстве	Cold start, сеть 4G, определенный набор данных
NFR-12	Ноль подтвержденных межпользовательских/региональных утечек	Негативные access tests и pentest

Медленные внешние интеграции работают асинхронно с timeout, status и retry. Приложение не держит HTTP-запрос открытым до результата проверки личности или позднего рекламного callback. Пользователь получает понятное pending-состояние.

Нагрузка тестируется с realistic mix: 60% чтение/поиск, 15% чат, 10% профиль/история, 10% команды заказа, 5% служебные действия. Дополнительно отдельно проверяются массовые webhooks, скан файлов, очередь удалений и истечение большого числа прав в один момент. Показатели смешанного и специализированного тестов не подменяют друг друга.

Метрики по регионам: latency/error rate, DB locks/connections, cache hit, queue lag, failed scan, webhook signature errors, reconciliation mismatch, reward pending age, no-fill, config publish failures и активные обращения. Алерт имеет владельца, порог, runbook и канал; сбор метрик без процесса реагирования не считается готовой эксплуатацией.

36 Стратегия тестирования и критические сценарии

Тесты разделяются на unit доменной логики, integration с реальными PostgreSQL/PostGIS/Redis, contract OpenAPI, end-to-end API, мобильные widget/integration, web UI, безопасность, локализацию и нагрузку. Внешние сервисы проверяются fake-провайдером и официальным sandbox; live smoke test допускается только после разрешенного подключения и расхода.

Обязательный набор критических проверок:

- T01 Регистрация/вход используют E.164 и Argon2id; неверный пароль не раскрывает наличие номера; нет SMS/телефонных кодов, phone unverified, пользовательского email нет; region-first не ищет по всем базам, занятый номер не присваивается
- T02 Два клиента одновременно выбирают разные отклики: ровно один assignment; редактирование заказа между preview и select дает конфликт
- T03 Истечение права блокирует новый поиск/отклик, но сохраняет чат, завершение, жалобу, export и restore
- T04 Повтор publish/message/purchase/reward с тем же ключом не создает дубликат; другой payload с тем же ключом дает конфликт
- T05 Webhook приходит дважды, в обратном порядке и после сетевого timeout: ledger и grant правильны после reconciliation

- T06 Клиент сообщает ad completed без SSV: права нет; валидный поздний SSV выдает ровно обещанную награду
- T07 No-fill, skip, crash, неверная подпись, чужая сессия и повтор transaction ID не выдают награду и не вызывают бесконечного экрана
- T08 Один завершенный заказ дает максимум два встречных отзыва; невыбранный отклик/closed_unconfirmed не дает звезд; двойная публикация job исключена
- T09 Block скрывает новые контакты; safety freeze оставляет поддержку; снятие block не снимает platform sanction
- T10 IDOR на профиль, заказ, чат, файл, case, export и admin запрещен для чужого аккаунта и региона
- T11 Вредоносный файл, ложный MIME, слишком большой файл и EXIF координаты обрабатываются по политике; quarantined URL не выдается
- T12 Удаление аккаунта удаляет поисковую проекцию/сессии, соблюдает retention и не обещает отмену магазинной подписки
- T13 Переключение banner/rewarded флагов не отключает подписку и не аннулирует оплаченный срок, renewal или начатый reward snapshot; баннер не дает grant, role switch не расширяет reward scope
- T14 Конфигурация без доступного законного канала не публикуется; отключение страны посреди заказа сохраняет safety scope; rollback создает новую audit-версию; все клиенты видят effective version
- T15 Повторное открытие сохраненной сессии требует PIN/биометрию или полный вход; отказ настройки не оставляет открытой сессии. Выход везде отзывает REST/WS; смена пароля требует полной проверки; refresh replay отзывает family; PIN/биометрия не обходят revoke, 5 ошибок и смена биометрии требуют полного входа
- T16 Потеря Redis, повтор job, временный отказ БД и восстановление backup не создают дубликатов или «бесплатных» вечных прав
- T17 Все языки, крупный текст, screen reader, keyboard, offline/reconnect и deep link работают без потери обязательных действий
- T19 Баннер не перекрывает UI, не сдвигает кнопку во время действия, не дает grant; выключение действует без релиза
- T20 Push campaign уважает consent/частоту/часовой пояс; retry не дублирует; запрещенный deep link отклонен; отмена останавливает неотправленное
- T21 Нулевой период подписки истекает в точную exclusive UTC-границу, включая DST и смену часов клиента: нет ретроактивной цены, нового списания без согласия или блокировки безопасности активного заказа
- T22 Безопасные test-tokens в каждом registry surface вызывают один quarantine+hold+case+admin event; несколько правил в одном тексте и retry не создают новые hold/case и не продлевают срок; whole-word/exception не дают ложных срабатываний
- T27 До passed исполнителю недоступны publish/portfolio/search_orders/offer/invite; customer и safety доступны; upload не дает verified; stale approval/revoke/expiry/race и cleanup брошенных ID-дел проверяются
- T28 Ни UI/API/schema/export/logs не собирают user email; admin IP/телефон/документы проверяют field/region ACL, MFA, sensitive-read audit и retention
- T29 Anonymous support capability не читает старые account objects; потеря/expiry/retry/спам, quote appeal без автohold; заявленный телефон не дает reset, support не выдает пароль
- T31 Top: like/dislike/undo/retry дают одну реакцию; self-vote недоступен; deleted/closed targets исключаются, tie deterministic, новые видны new-sort; stars только completed-reviews

- T32 Boost: paid/admin provenance, capacity/overlap race и запрет снижения обещанной емкости; end≤order expiry; receipt/start повторяют eligibility; late payment/refund/V revoke скрывают показ; organic score неизменен
- T33 Цена любой подписки/boost/promo берется из опубликованного catalog/provider snapshot; admin update без релиза, невозможный price point отклонен; существующий договор/бюджет заказа не переписывается
- T30 Blacklist вручную требует case/evidence/reason, имеет expiry/appeal; delete отделен от ban, уважает legal hold и не отменяет store subscription
- T26 Портфолио: старое approve не публикует измененную/удаленную ревизию; own CRUD/reorder/cover и publish gate; чужие ID/draft недоступны; scan и словарь блокируют показ; completed-link только своего assignment, отзыв статуса снимает значок; report/archive/retention и offline lightbox
- T25 Referral: два кода закрепляют только первый действительный; self-invite/replay блокируются; один milestone дает один бонус; refund и смена campaign сохраняют audit, provider failure не сжигает награду; гонка атрибуций резервирует один milestone и не превышает cap; stop сохраняет старые резервы
- T24 Launcher-иконка: crop без искажения, MIME/scan/pixel guards, iOS assets/Android adaptive safe zone и masks; версия входит в тестовую сборку; upload не меняет установленное приложение и не публикует store release
- T23 Изменение словаря не банит старых авторов; истечение hold снимает ограничение без автопубликации контента; апелляция с цитатой не запускает цикл; ручные действия проверяют роли и аудит
- T18 Invite-to-order проверяет владельца, лимит, блокировки и expiry; принятие не создает assignment без обычного отклика/выбора

Для каждой найденной ошибки сохраняются воспроизведение, ожидаемое/фактическое, affected FR, severity и regression test. Test fixtures только синтетические. Запись реальной переписки или документов в snapshot запрещена.

37 Матрица требований и приемки

Каждая строка принимается демонстрацией результата и автоматическим тестом там, где он возможен. Слова «экран есть» или «сборка прошла» не доказывают бизнес-функцию. Если P0-решение открыто, затронутая страна/функция остается disabled.

Требование	Приемочный результат AC	Проверка
FR-001–002	Заказчик и исполнитель проходят полный цикл одного заказа	E2E обоих клиентов
FR-003	Роль, право, регион и владение проверяются сервером	T10, negative RBAC
FR-004	Все заданные локали, валюты и legal versions доступны	T17, вычитка носителем
FR-005	Региональные данные и backups не пересекаются неразрешенно	Architecture review, T01/T10
FR-006–007	Телефон + пароль без SMS, Argon2id, unverified phone, revoke; recovery только после D17	T01/T15, takeover tests
FR-008–009	Local unlock отдельно; документ исполнителя обязателен до executor gates, human review и защищенное хранение	T15/T27, role/revision/privacy tests
FR-010	Экспорт/удаление/согласия доступны без paywall	T03/T12

Требование	Приемочный результат AC	Проверка
FR-011–012	Профиль, категории, поиск и георадиус корректны	Search fixture, boundary tests
FR-013–014	Ревизии, публикация, terminal states и один assignment	T02/T04
FR-015–015A	Отклик, invite и подтверждение новых условий работают	T02/T18
FR-016–017	Чат без потерь/дубликатов, inbox и privacy-safe push	T04/T10/T17
FR-018–019	Завершение/отмена/спор имеют конечный и аудируемый путь	State-machine tests
FR-020	Только допустимые взаимные отзывы, double blind и appeal	T08
FR-021–022	Pair block, platform sanction и appeal независимы	T09/T10
FR-023	Право проверено сервером; grandfathering только своего заказа	T03/T16
FR-024	Проверка receipts, restore, renewal, refund и reconciliation	T04/T05
FR-025–026	Законный ad flow, SSV, no-fill и защита повторов	T06/T07
FR-027–028	Scoped admin, MFA, reason и неизменяемый audit	RBAC/pentest
FR-029	Полный OpenAPI, стабильные ошибки и idempotency	Contract CI
FR-030	Все S/W/A экраны и обязательные состояния проверены	UI checklist, T17
FR-031–032	Подписка сохраняется; banner/rewarded независимы, publish/rollback без кода	T13/T14
FR-033	Ad income estimated/finalized отделен от SSV и grants	Reconciliation fixture
FR-034–035	Inline banners и admin push не нарушают UX, согласия и права	T19/T20
FR-036	Нулевая подписка до даты, затем подтвержденный платный тариф без неожиданного списания	T21, schedule/consent tests
FR-037	Словари по языкам, карантин, временный auto hold, admin alert и человеческое решение	T22/T23, registry completeness
FR-038	Launcher-исходник, crop, preview, version/approval, генерация ресурсов и управляемый новый релиз	T24, A19, native build review
FR-039	Одноуровневые приглашения, admin campaign, квалификация, бонусный ledger и provider-safe redeem	T25, S37/A20, anti-abuse review
FR-040	Портфолио проектов с фото, собственные ревизии/порядок/обложка, безопасный просмотр и модерация	T26, S08/S38/S39, access/scan tests
FR-041–042	Подробная scoped admin-карточка без email, полный IP при праве, blacklist и отдельное удаление	T28/T30, A03/A07/A12, access review
FR-043	Support chat без paywall, pre-login recovery ticket с отдельным capability и проверкой владения	T29, S40/A21, recovery threat model
FR-044	Два Топ-100, реакции и версионируемая популярность отдельно от реальных звезд	T31, S41/A22, ranking fixtures
FR-045	Разовые paid/admin boosts с ценами из админки, емкостью, ledger и отдельной маркировкой	T32/T33, S42/A22, billing/capacity tests
NFR-01–12	Измеренные показатели на описанном стенде	Load, restore, telemetry report

Definition of Done для функции: утвержденный UX/контракт; миграции; server и client implementation; unit/integration/E2E; перевод; права и threat review; metrics/log masking;

обработка ошибок/offline; документация; review и CI. Feature flag по умолчанию закрыт до выполнения приемки.

Definition of Release: все P0 закрыты, нет блокирующих дефектов, пройдены smoke/restore/security, подписаны store/privacy формы, реальные провайдеры подтверждены, назначена поддержка и incident owner, rollout/rollback проверены. Отключенный модуль с пустой кнопкой не засчитывается как выполненное требование.

38 Окружения CI резервирование и эксплуатация

Окружения: local, test/CI, staging по регионам и production по регионам. Разные базы, buckets, secrets, bundle/application IDs либо test configuration, webhook endpoints и ключи. Production credentials никогда не используются для локального запуска; sandbox purchase не выдает production grant.

Локальный запуск: документированные команды, .env.example, Docker Compose с PostgreSQL/PostGIS, Redis, S3-compatible emulator и fake adapters. Seed содержит страны, переводы, категории и синтетические аккаунты. Платежи, реклама, push и ID checks по умолчанию fake; переключение на реального провайдера требует явной конфигурации и разрешений.

CI для PR: formatter/lint, typecheck, unit, migrations на чистой БД, integration, OpenAPI compatibility, web build, Flutter analyze/test, dependency/secret scan. Отдельные pipeline собирают Android и iOS на подходящих runners; отсутствие macOS runner не маркируется как успешная iOS-сборка. Подписи и загрузка в магазины — защищенный release flow.

Деплой: immutable artifact и commit SHA; approval; expand migrations; health/readiness; canary или ограниченная аудитория; smoke; наблюдение метрик; расширение. Флаги позволяют отключить новый monetization flow, провайдера или страну без удаления оплаченных прав. Нельзя отключать privacy/support ради maintenance платных функций.

Rollback приложения совместим с текущей схемой. Для destructive data migration подготовить backup, restore rehearsal и отдельное окно; rollback бинарника не считается автоматическим откатом данных. Конфигурации имеют версию и effective_at; клиентов старой версии проверяют на server policy, а не полагаются на обновление UI.

Backup: непрерывное журналирование/PITR PostgreSQL с целевым RPO 15 минут; ежедневная полная/базовая копия; шифрование и региональная изоляция; предложенное хранение 30 дней; ежемесячный restore drill и квартальный полный disaster recovery сценарий. Удаления должны повторно применяться после восстановления, чтобы не воскресить удаленные аккаунты.

Runbooks: недоступность API/БД, dead-letter очередь, пропущенный webhook, неверная цена, массовый no-fill, fraud attack, компрометация ключа, блокировка store, потеря региона, утечка и privacy request backlog. Контактный owner и escalation определяются до запуска, не оставляются «командой» без ответственного.

Наблюдаемость: structured logs с redaction, traces без тел чувствительных запросов, dashboards по SLO, correlation request/event IDs и alert routing. Стоимость по региону/сервису/провайдеру контролируется бюджетными уведомлениями; инфраструктурный autoscale имеет верхний лимит.

39 Этапы реализации и зависимости

Срок и бюджет определяются после утверждения P0-решений, дизайна и состава команды. Перечисленные этапы задают порядок и критерии выхода; они не являются обещанием готовности всего продукта к фиксированной дате.

Этап 0 Продуктовые и правовые решения. Для выбранного названия JOBA определить оператора, launch countries, регионы, договоры, платежи, рекламную политику, географию, законную обязательную проверку исполнителя, правила подписки и retention. Результат: утвержденные D-решения и country matrix; неподтвержденные страны выключены.

Этап 1 Основа и контракты. Monorepo, local compose, CI, migrations, OpenAPI, region-first bootstrap, phone/password auth без SMS, сохраненная сессия и local unlock, роли, legal versions, UI shell и i18n. Результат: воспроизводимый запуск на чистой машине, вход и negative authorization tests. Наличие health endpoint само по себе этап не закрывает.

Этап 2 Полный вертикальный сценарий. Профиль исполнителя, каталог, геопоиск, draft/publish, приглашение, отклик, transactional select, чат, completion/cancel. Fake billing/ad adapters доступны только для теста. Результат: два клиента выполняют один синтетический заказ и проходят гонки/ошибки.

Этап 3 Доверие и администрирование. Взаимные отзывы, блокировки, case workflow, апелляции, support, audit, privacy export/delete, file quarantine, профиль заказчика, доступность/локализация. Результат: модератор закрывает реальные тестовые кейсы без прямой правки БД.

Этап 4 Коммерческий доступ. Подписки, store receipts/webhooks, refund/reconciliation, rewarded SSV, независимые баннерные настройки, admin version/preview/schedule/publish/rollback, country gates и revenue reports. Результат: provider sandbox и все T03–T07/T13–T14; production включается только после разрешенных live проверок.

Этап 5 Устойчивость и пилот. Нагрузка, security review, restore drill, все локали, mobile native builds, тестовые store submissions, operational runbooks, support readiness и ограниченная аудитория. Результат: release checklist и документированные отклонения; нет неустраненных P0.

Этап 6 Расширение. По очереди включить остальные страны после независимых gates; улучшать поиск по фактическим данным; отдельно оценить P2 веб-кабинет, календарь, команды и расчеты за реальные услуги. Включение новой страны не равно добавлению перевода строки в конфигурацию.

Параллельно могут идти UX и backend contracts, мобильные экраны и доменные модули, localization и QA fixtures. Платежи/реклама/ID-провайдеры зависят от договоров и страны; их нельзя поставить в конец как гарантированно быструю интеграцию. Владельцы результатов: product, technical lead, mobile/web/backend, QA, security/privacy и operations назначаются отдельно.

40 Репозиторий и комплект передачи

По выбору пользователя репозиторий публичный: [milaniumkz/services-marketplace](). Название приложения — JOBA; название и URL репозитория сохраняются. Публичность требует особой проверки секретов и персональных данных; лицензия и права на сторонние материалы

выбираются отдельно, наличие публичного кода само по себе не означает определенную open-source лицензию.

Предлагаемая структура: services/api, apps/mobile, apps/admin, apps/web; packages/contracts, packages/config, packages/test-fixtures; infra/local, infra/deploy; docs/spec, docs/adr, docs/runbooks; scripts. Допустимо изменить физические пути под уже созданную основу, сохранив ясные границы и документацию.

Комплект передачи должен содержать:

- README с prerequisites, версиями, быстрым стартом, командами тестов и известными ограничениями
- Полное это ТЗ в DOCX/PDF/Markdown, журнал решений и список открытых P0
- Исходники всех согласованных приложений и backend, lock-файлы, migrations, safe seeds и generated contracts
- OpenAPI, ER-диаграмму, state machines, перечень событий/jobs и ошибок
- Дизайн-макеты и компоненты, исходники графики с лицензиями, переводы и проверку доступности
- Environment inventory, .env.example, секреты через согласованный защищенный канал вне репозитория
- Provider configuration guide: SKU, webhooks, SSV, sandbox/prod boundaries, callbacks и allowed redirects
- CI/CD, test report, load report, security findings и исправления, доказательство native builds
- Backup/restore, rollout/rollback, incident, privacy и support runbooks
- Учет store ownership, signing identities, доменов, служебных контактов оператора и договоров; доступ выдается минимально необходимый

Проверенный исходный статус основы на 12 октября 2026 года: в main commit 5e2f4de23127e1dec9366817e2174bbdd9667bfc существовал технический каркас; сборки NestJS health и admin прошли, бизнес-маршрут /orders отсутствовал. Draft PR № 1 на последнем проверенном commit cd6b5063806e3b2383b0ee3ea53aedcb5ceb3bf2 включал Flutter runners и основу настроек subscription_enabled=true с независимыми banner/rewarded флагами; demo-страны оставались unverified с выключенным checkout. Проверены сборки API/admin/contracts и 4 теста; Flutter analyze и один тест проверялись на предыдущем commit 919a3ff0959b4d2b8ce5e13008268c4da548a0d3. Native build/signing и PostgreSQL не проверены.

Этот снимок не подтверждает выполнение полного ТЗ и не заменяет проверку актуального HEAD. Перед передачей разработчик формирует таблицу implemented/partial/not_started по FR и указывает точный commit, CI run и тестовые результаты. Неисполненные бизнес-функции должны быть названы прямо; scaffold не маркируется как готовый marketplace.

Не публиковать production databases, реальные пользовательские файлы, токены, сырые чеки, приватные юридические документы и чувствительные логи. Отдельно проверить историю Git до первого push и после каждого инцидента; удаление файла из текущего дерева не удаляет секрет из истории.

41 Решения и обязательные проверки

ID	Решение	Влияние и ответственный
D01 частично закрыто	Название JOBA выбрано; домен, юридическое лицо и контакт поддержки не определены	Владелец; правовые документы и договоры
D02	Порядок запуска стран и допустимые регионы хранения	Владелец + местный юрист + архитектор; P0
D03	ADR-REGION-01 глобальная уникальность и межрегиональные санкции	Privacy/security; P0 многорегионального запуска
D04	Store publisher entity, доступные SKU и схема России	Billing/legal; P0 коммерческого доступа
D05	Допустимость core pay-or-reward gate и рекламный провайдер	Legal + provider; P0 rewarded
D06	Цена, период подписки, trial если нужен, cohort policy	Владелец; никакого trial по умолчанию
D07	Duration или credits за награду, роль, лимиты и cooldown	Владелец; числа раздела 21 предложены
D08	Скрывать сторонние баннеры у платных подписчиков	Рекомендуется; владелец утверждает
D09 частично закрыто	Документ исполнителя обязателен; утвердить законный country flow и retention	Privacy/legal/product; liveness не обязателен, P0 допуска исполнителя
D10	Финальные сроки retention и обязательного учета	Юрист по каждой стране; P0 данных
D11	Карты/геокодер, покрытие, лицензии и SDK передачи	Архитектор/legal; P0 геосервиса
D12	Возраст 18+, категория лицензируемых услуг и запреты	Legal/product; P0 допуска
D13	SLA поддержки, часы работы, окно отзывов и апелляций	Владелец/operations
D14	Сербская кириллица по умолчанию и латиница	Product/localization
D20	Утвердить окно/формулу Топа, placement capacity и boost policy/цены/компенсации	Владелец/Billing; примеры не тариф, country/store gates обязательны
D19	Реферальный порог, qualifying event, тип/срок бонуса, бюджет и stacking	Владелец/Billing; пример 5 человек и 500→200 ₸ не тариф; P0 включения кампании
D18 закрыто	Пользователь уточнил: иконка приложения launcher	FR-038; новые изображения через сборку/релиз, alternate icons только optional P2
D17	Утвердить recovery без SMS/email: код, доверенное устройство, ручная проверка доказательств	Владелец/security; варианты предложены; unverified phone не основание reset; P0

ID	Решение	Влияние и ответственный
D16 закрыто	Выбрана цена подписки 0 до даты, далее платный тариф	Подтверждено пользователем; комиссия с заказа исключена
D15	Полный web-кабинет в P1 или P2, лицензия репозитория	Владелец; объем и права на код

Правовые направления по официальным источникам:

- Казахстан: закон предусматривает хранение в базе на территории страны и отдельно регулирует трансграничную передачу; проверить согласия, минимизацию и права при автоматизированных значимых решениях
- Россия: проверить актуальные требования локализации первичного сбора, уведомления оператора и отдельную процедуру трансграничной передачи; использование биометрии требует самостоятельной оценки. Публичные разъяснения не заменяют сверку консолидированного закона на дату запуска
- Беларусь: проверить специальные условия биометрических данных, основания передачи за рубеж, цели и пропорциональность хранения
- Сербия: проверить специальные категории данных/биометрию, необходимость impact assessment, основание обработки и механизм международной передачи

ТЗ не является юридическим заключением. Нельзя объявить проект «полностью соответствующим закону» на основании выбранного сервера, чекбокса согласия или договора с одним провайдером. Для каждой включенной страны хранится дата проверки, утвержденные документы и owner следующего пересмотра.

Отдельные продуктовые риски: недостаток заказов/исполнителей в городе, фальшивые отзывы, недобросовестный заказчик, вымогательство отзывом, no-fill, падение подписок, межрегиональный обход санкций и ложные ID проверки. Метрика риска и действие должны быть определены до масштабирования, без обещания полностью исключить мошенничество.

42 Официальные источники и основания решений

Дата проверки источников: 12 октября 2026 года. Политики магазинов и провайдеров меняются; перед запуском обновить evidence registry. Ссылки приведены для проверки конкретных ограничений, а не как одобрение проекта соответствующими организациями.

Магазины и подписки

1. Apple App Review Guidelines — цифровые функции 3.1.1, реальные услуги 3.1.3(e), вход 4.8 и допустимые incentivized actions 3.2.2(x). Не применять устаревший общий запрет rewarded-рекламы.

2. Google Play Payments policy — правила цифровых покупок и исключения.

3. Google Play Russia and Belarus developer FAQ — приостановка Billing в России и отличие платных загрузок Беларуси от IAP в бесплатном приложении.

4. Apple purchases in Russia — ограничения покупок и пополнения баланса с 1 апреля 2026 года.

5. Apple subscription pricing и Google subscription price changes — управление ценой и существующими подписчиками.

6. Google account deletion requirements — доступный сценарий удаления в приложении и вне его.

Реклама и подтверждение награды

7. Google rewarded ad policies — условия добровольности и нормального использования; основание launch gate для полного pay-or-ad доступа.

8. Google publisher restrictions for Russia and Belarus — ограничения спроса в России, third-party waterfall и ограничения страны аккаунта издателя.

9. AdMob server-side verification — подписанные callbacks, transaction ID и проверка награды.

Идентификация и местоположение

10. Google OpenID Connect — только для возможного будущего OAuth; P1 использует телефон и пароль без SMS. При будущем OAuth использовать issuer + sub; email claim не запрашивать/не сохранять.

11. Apple Face ID security — локальная защита биометрии; не эквивалент проверки документов.

12. W3C Geolocation — разрешение, точность и время координат. Применение к native UI требует соответствующих платформенных API.

Персональные данные и рыночный контекст

13. Закон Казахстана о персональных данных — статьи 7–8, 12, 16 и 19-1; локальное хранение, передачи и автоматизированные решения.

14. Разъяснение прокуратуры РФ о локализации, уведомлениях и биометрических данных — темы для обязательной актуальной местной правовой проверки.

15. Закон Беларуси на сайте регулятора — цели, пропорциональность, специальные категории и передачи.

16. Уполномоченный Сербии по защите данных — официальный раздел законодательства и надзора; проверить применимые статьи и механизм передач.

17. Naimi и официальный FAQ — концептуальный пример поиска специалистов, заказов и откликов. Дизайн, тексты, бренд и закрытые материалы не копируются; собственная модель монетизации не приписывается Naimi.

Для каждого выбранного SDK дополнительно включить в репозиторий ссылку на актуальную интеграционную документацию, условия обработки данных, поддерживаемые страны и версию. При расхождении документация провайдера и юридически обязательные требования проверяются до изменения продукта.

18. Apple: app icon и обновление версии, Apple: встроенные alternate icons. Основа FR-038; повторно проверить требования toolchain на дату релиза.

19. Android activity-alias, Google Play icon specifications, Google Play Device and Network Abuse. Разделение launcher/store icon и согласие на изменения устройства.